

INFORME DE RECONOCIMIENTO DIGITAL



Recopilación y análisis de información pública disponible mediante técnicas de footprinting pasivo/activo, fingerprinting de tecnologías expuestas y OSINT

Gustavo Alvarez Sanchez

06/03/2026

1. Introducción

Objetivo del análisis: TomTom (tomtom.com)

TomTom N.V. es una empresa multinacional neerlandesa fundada en 1991 en Ámsterdam, especializada en **tecnología de geolocalización** y soluciones de movilidad. Inicialmente conocida por revolucionar la navegación personal con dispositivos GPS portátiles (lanzados masivamente a partir de 2004 y convirtiéndose en uno de los productos electrónicos de consumo de mayor éxito en su época), la compañía ha evolucionado hacia un proveedor líder e independiente de mapas digitales de alta precisión, software de navegación, información de tráfico en tiempo real y servicios conectados para vehículos.

En la actualidad (2026), TomTom se posiciona como uno de los principales actores independientes en el sector de la cartografía y la location technology, con un enfoque B2B muy fuerte. Sus productos y plataformas —destacando **TomTom Orbis Maps** (lanzada en 2022 como una plataforma abierta y flexible que integra datos propios con fuentes como Overture Maps Foundation y OpenStreetMap)— alimentan sistemas de navegación en automóviles, soluciones de conducción autónoma y asistida (ADAS), aplicaciones móviles, gestión de flotas, y servicios para fabricantes de vehículos, gobiernos y desarrolladores. La empresa opera a nivel global, con presencia en más de 29 países, alrededor de 3.300–3.600 empleados y oficinas en Europa, Norteamérica y Asia-Pacífico. Su sede central sigue ubicada en Ámsterdam, Países Bajos.

El dominio principal **tomtom.com** sirve como portal corporativo oficial y punto de entrada a sus servicios, donde se ofrecen:

- Información corporativa y de productos.
- Acceso a APIs y SDKs de mapas y localización.
- Descargas de actualizaciones para dispositivos y apps de navegación.
- Secciones de soporte, carreras y contacto.
- Enlaces a plataformas especializadas como automotive.tomtom.com o traffic.tomtom.com.

Objetivo del presente informe

El propósito de este análisis es realizar una recopilación exhaustiva y sistemática de información pública disponible sobre la organización TomTom a través de técnicas de **OSINT** (Open Source Intelligence), **footprinting** (reconocimiento pasivo y activo del perímetro digital) y **fingerprinting** (identificación de tecnologías, servicios y configuraciones expuestas).

Este ejercicio busca identificar y documentar elementos como:

- Infraestructura expuesta (subdominios, IPs, servidores, certificados SSL, etc.).
- Tecnologías web y stack utilizado en tomtom.com y dominios relacionados.
- Presencia digital (perfiles en redes sociales, repositorios, leaks, menciones en fuentes abiertas).
- Información corporativa, empleados clave, correos, partners y posibles vectores de ataque o puntos de interés desde una perspectiva de seguridad.

Todo el proceso se realiza de manera ética, utilizando únicamente fuentes públicas y sin interacción intrusiva ni explotación de vulnerabilidades, con el fin de evaluar la huella digital visible de la organización y destacar posibles riesgos asociados a la exposición de información.

2. Footprinting y Reconocimiento de Infraestructura

2.1 Herramienta: RIPE Database – Búsqueda de rangos de IP asignados

Herramienta utilizada: RIPE Database (interfaz web en ripe.net o whois.ripe.net).

Descripción del proceso:

Se realizó una consulta en la base de datos pública de RIPE NCC (Registro de Internet para Europa) buscando por la organización "TomTom International B.V." o el dominio asociado "tomtom.com". El objetivo fue identificar los rangos de direcciones IP (inetnum) y el Autonomous System Number (ASN) registrados a nombre de la empresa.

Resultados obtenidos:

- Se identificó un único rango principal IPv4 asociado: **185.5.120.0 - 185.5.123.255**
- ASN asociado: **AS49838** (TomTom International B.V.).
- No se encontraron múltiples rangos grandes ni bloques IPv6 relevantes en esta consulta inicial.

Captura de pantalla:

The screenshot shows the RIPE Database search interface. At the top, there is a search bar with 'tomtom.com' entered and a 'Search' button. Below the search bar, there is a link to 'Advanced Search' and a disclaimer: 'By submitting this form you explicitly express your agreement with the [RIPE Database Terms and Conditions](#)'. The search results section is titled 'Search results' and contains the text: 'This is the RIPE Database full text search service. The RIPE Database is subject to [Terms and Conditions](#)'. Below this, there is a table showing the number of results for all object types. The table has two columns: 'Number of results - all object types' and a numerical value. The results are as follows:

Number of results - all object types	
24	
17	person
2	role
1	inet6num
1	inetnum
1	mntner
1	organisation
1	route

Below the table, there are three pagination buttons: '1', '2', and '3'. At the bottom, there is a link to 'inetnum: 185.5.120.0-185.5.123.255' and a link to 'notify=ripe@tomtom.com'.

(Resultado de la consulta en RIPE Database mostrando el rango IP)

2.2 Herramientas: echo + mapcidr + dnsx – Consulta inversa en el rango IP para descubrimiento de subdominios

Herramientas utilizadas:

- echo (para definir el rango).
- mapcidr (para expandir el CIDR en lista de IPs).
- dnsx (para resolución inversa PTR en masa).

Descripción del proceso:

1. Se definió el rango obtenido previamente con **echo**.

2. Se desglosó el rango en direcciones IP individuales (o manejables) con **mapcidr**.
3. Se realizó una consulta DNS inversa masiva con **dnsx**: se tomó la lista de IPs y se buscaron registros PTR (pointer) que resolvieran a nombres de dominio.
4. Los resultados se filtraron para incluir solo entradas relacionadas con tomtom.com o tomtomgroup.com y se guardaron en un archivo.
5. Comando completo: `echo 185.5.120.0-185.5.123.255 | mapcidr -silent | dnsx -ptr -resp-only > subdominios_rango_ips_horizontal.txt`

Resultados obtenidos:

A continuación, se destacan los subdominios más relevantes identificados con esta herramienta:

- **api.moma.tomtom.com** → API relacionada con MOMA (posiblemente Maps o Mobile Maps).
- **test-api.moma.tomtom.com** → Versión de testing de la API anterior.
- **wmswfs-geo.tomtom.com** → Servicios geográficos WMS/WFS (Web Map Service / Web Feature Service).
- **inframixtrafficsevice.tomtom.com** → Servicio de tráfico Inframix (integración vial avanzada).
- **salesforce-sso.tomtom.com** → Single Sign-On con Salesforce.
- **mit-preprod-auth.tomtom.com** → Autenticación en preproducción (posible Map Input Tracker).
- **mapinputtracker-auth.tomtom.com** → Autenticación para tracker de inputs de mapas.
- **prod-perseus-worldwide-nissan-vip.tomtom.com** → Entorno producción Perseus para Nissan (partner automotriz).
- **tts-daimler-worldwide.tomtom.com** → Servicios TTS para Daimler (Mercedes).
- **tts-worldwide-preprod-bmw.tomtom.com** → Preproducción TTS para BMW.
- **office365.tomtom.com** → Integración con Microsoft 365 / Office.
- **outbound.tomtomgroup.com** (y variantes outbound-am2 / outbound-am3) → Servidores de correo saliente SMTP.
- **protect.tomtom.com** → Posible servicio de protección/seguridad.

- **jira-dev-ext.tomtomgroup.com** → Jira externo/desarrollo (posible exposición de issues internos).
- **pushfeed-ssl-receiver.tomtom.com** → Receptor de push feeds SSL (actualizaciones en tiempo real).

Captura de pantalla:

```
(kali@kali)-[~/recopilacion_practica]
$ echo 185.5.120.0-185.5.123.255 | mapcidr -silent | dnsx -ptr -resp-only > subdominios_rango_ips_horizontal.txt

projectdiscovery.io

[INF] Current dnsx version 1.2.3 (latest)

(kali@kali)-[~/recopilacion_practica]
$ ls
analytics.txt  cero.txt  ctfr.txt  katanalimpio.txt  katana.txt  subdominios_rango_ips_horizontal.txt  subdominios.txt

(kali@kali)-[~/recopilacion_practica]
$ cat subdominios_rango_ips_horizontal.txt
test-statcity-indexweb-vip.tomtom.com
mit-preprod-auth.tomtom.com
preprod-bilston-pushfeed-receiver-vip.tomtom.com
prod-muskoka-moodle-vip.tomtom.com
emdass.tomtomgroup.com
pnd-platform-gerrit.tomtom.com
offtp.tomtom.com
cpp.tomtom.com
salesforce-sso.tomtom.com
sporemoteapp.tomtom.com
protect.tomtom.com
office365.tomtom.com
mail4.tomtom.com
lsaccess.tomtom.com
lswebconf.tomtom.com
lsav.tomtom.com
lsaccess.tomtom.com
lswebconf.tomtom.com
cpp-sources.tomtom.com
lswebext03.tomtom.com
connect-be.tomtom.com
csdp.tomtomgroup.com
sbcam2.tomtomgroup.com
outbound.tomtomgroup.com
h2-preprod.tt1.nl
mapinputtracker-auth.tomtom.com
mapinputtracker.tt1.nl
solaris-cambridge-proxy-vip.tomtom.com
partnerlink-test.tomtom.com
test-nyproxy-public-vip.tomtom.com
```

(Cadena de comandos echo → mapcidr → dnsx mostrando la expansión del rango y resultados de consulta inversa PTR, con subdominios guardados.)

Observaciones / hallazgos relevantes:

- El proceso es mixto: combina footprinting vertical (profundizar en el dominio principal tomtom.com) con horizontal (explorar otros hosts en el mismo bloque IP).

- Muchos subdominios incluyen sufijos como "-vip" (indicando Virtual IP / balanceo de carga), "-preprod", "-test", "-prod" o nombres de partners (ej. nissan, bmw, daimler), sugiriendo entornos de producción, testing y servicios especializados.

2.3 Herramienta: shuffledns – Enumeración activa de subdominios mediante diccionario

Herramienta utilizada:

- **shuffledns** (herramienta de para resolución masiva y permutación de subdominios).
- Resolvers válidos (obtenidos/actualizados con **resolvalid** , para mejorar precisión y evitar falsos positivos).

Descripción del proceso:

1. Se preparó un diccionario/wordlist de subdominios comunes y específicos (shuffledns.txt), enfocado en patrones típicos de empresas tecnológicas (mail, api, dev, traffic, office, etc.).
2. Se actualizó una lista de resolvers DNS válidos y rápidos (con resolvalid) para evitar timeouts y mejorar la fiabilidad.
3. Se ejecutó shuffledns contra el dominio principal **tomtom.com**, pasándole el diccionario y los resolvers.
4. Comando: `shuffledns -mode bruteforce -d tomtom.com -w $HOME/recopilacion/lists/domains.txt -r $HOME/recopilacion/lists/resolvers.txt -silent > subdominios.txt`

Resultados obtenidos:

Se utilizó un wordlist con entradas comunes y shuffledns identificó varios subdominios válidos que resolvieron exitosamente.

A continuación, se destacan los subdominios más relevantes descubiertos con esta herramienta:

- **api.tomtom.com** → Endpoint principal de APIs (core para mapas, routing, tráfico).
- **developer.tomtom.com** → Portal oficial para desarrolladores (SDKs, documentación APIs).

- **traffic.tomtom.com** → Servicios de tráfico en tiempo real.
- **office365.tomtom.com** → Integración con Microsoft 365 / Office.
- **protect.tomtom.com** → Posible servicio de protección o seguridad.
- **cpp.tomtom.com** → Posiblemente relacionado con C++ sources o plataforma interna.
- **ny.tomtom.com** → Subdominio geográfico (Nueva York, posiblemente oficina o proxy).
- **maps.tomtom.com** → Portal o acceso a mapas.
- **help.tomtom.com** → Soporte y ayuda (posible knowledge base).
- **download.tomtom.com** → Descargas de software/actualizaciones.
- **status.tomtom.com** → Página de estado de servicios.
- **support.tomtom.com** → Portal de soporte técnico.
- **events.tomtom.com** → Eventos o webinars corporativos.

Captura de pantalla:

```

(kali@kali)-[~/tomtom.com]
$ shuffledns -mode bruteforce -d tomtom.com -w $HOME/recopilacion/lists/domains.txt -r $HOME/recopilacion/lists/resolvers.txt -silent > shuffledns.txt

(kali@kali)-[~/tomtom.com]
$ cat shuffledns.txt
docs.tomtom.com
helpdesk.tomtom.com
reporting.tomtom.com
promo.tomtom.com
training.tomtom.com
repository.tomtom.com
home.tomtom.com
plus.tomtom.com
sweet.tomtom.com
mail2.tomtom.com
enterpriseenrollment.tomtom.com
oauth.tomtom.com
compass.tomtom.com
status.tomtom.com
support.tomtom.com
events.tomtom.com
ocsp.tomtom.com
images.tomtom.com
opensource.tomtom.com
messaging.tomtom.com
cpp.tomtom.com
webmail.tomtom.com
mail4.tomtom.com
dialin.tomtom.com
meet.tomtom.com
mail3.tomtom.com
mailtest.tomtom.com
protect.tomtom.com
proxy.tomtom.com
ny.tomtom.com
learn.tomtom.com
corporate.tomtom.com
developer.tomtom.com
register.tomtom.com

```

(Ejecución de shuffledns mostrando el comando, wordlist cargado (shuffledns.txt), uso de resolvers válidos y output parcial de subdominios resueltos.)

Observaciones / hallazgos relevantes:

- El wordlist incluyó combinaciones comunes (mail*, dev*, api*, traffic*, etc.), lo que permitió descubrir subdominios funcionales no necesariamente expuestos en rangos IP previos.
- Muchos subdominios resueltos corresponden a servicios públicos/externos (dev, api, traffic), mientras que otros podrían ser internos o legacy (mail*, proxy*).

2.4 Herramienta: analyticsrelationships – Búsqueda de subdominios y sitios relacionados vía Google Analytics IDs

Herramienta utilizada: analyticsrelationships (herramienta OSINT para extraer y correlacionar IDs de Google Analytics/Universal Analytics/GA4 desde páginas web y descubrir dominios/subdominios que comparten los mismos trackers).

Descripción del proceso:

1. Se ejecutó la herramienta contra el dominio principal **tomtom.com**
2. El proceso implica:
 - Acceder a la página principal y/o subpáginas de tomtom.com.
 - Extraer los IDs de Google Analytics presentes en el código fuente (UA-XXXXX-X, G-XXXXXX, etc.).
 - Usar esos IDs para consultar bases de datos públicas o APIs que correlacionan trackers con otros dominios/subdominios que los utilizan.
3. Comando: *analyticsrelationships -u tomtom.com > analytics.txt*

Resultados obtenidos:

No se encontraron subdominios ni dominios relacionados adicionales mediante esta técnica.

Captura de pantalla:

```
(kali㉿kali)-[~/tomtom.com]
$ analyticsrelationships -u tomtom.com > analytics.txt
/usr/bin/analyticsrelationships:34: SyntaxWarning: invalid escape sequence '\d'
  pattern = "UA-\d+-\d+"
/usr/bin/analyticsrelationships:47: SyntaxWarning: invalid escape sequence '\.'
  pattern = "(www\.googletagmanager\.com/ns\.html\?id=[A-Z0-9\-\_]+)"
/usr/bin/analyticsrelationships:49: SyntaxWarning: invalid escape sequence '\d'
  pattern3 = "UA-\d+-\d+"
/usr/bin/analyticsrelationships:78: SyntaxWarning: invalid escape sequence '\-'
  pattern = "/relationships/[a-z0-9\-\_\.\_]+\.[a-z]+"

UA-ID
DOMAINS

> Get related domains / subdomains by looking at Google Analytics IDs
> Python version
> By @JosueEncinar

[+] Analyzing url: https://tomtom.com
[-] Tagmanager URL not found

(kali㉿kali)-[~/tomtom.com]
$ cat analytics.txt
```

(Resultado de la ejecución de analyticsrelationships contra tomtom.com, mostrando ausencia de subdominios o sitios relacionados vinculados por IDs de Google Analytics.)

Observaciones / hallazgos relevantes:

- La ausencia de resultados puede deberse a que TomTom utiliza métodos de tracking modernos (GA4 con server-side tagging, o trackers propios/no-Google), o que los IDs no están expuestos públicamente en correlaciones conocidas.
- Este paso complementa la enumeración previa, aunque en este caso no aportó nuevos hallazgos.

2.5 Herramienta: **cero** – Descubrimiento de dominios y subdominios vía certificados SSL/TLS

Herramienta utilizada: **cero** (herramienta open-source para scrapear nombres de dominio y subdominios desde certificados SSL/TLS proporcionados durante el handshake TLS en hosts remotos; soporta dominios, IPs, rangos CIDR e IPv6).

Descripción del proceso:

1. Se ejecutó **cero** contra el dominio principal **tomtom.com** y/o rangos/subdominios previamente identificados (posiblemente combinado con el rango RIPE o listas existentes).
2. La herramienta se conecta a hosts, inicia el handshake TLS y extrae los Subject Alternative Names (SANs) y Common Name (CN) de los certificados presentados.
3. Comando: `cero -d tomtom.com > cero.txt`

Resultados obtenidos:

Se descubrieron varios dominios y subdominios a través de los certificados SSL/TLS analizados.

A continuación, se destacan los dominios y subdominios más relevantes identificados con esta herramienta:

- **tomtom.com** → Dominio principal.
- **tomtomgroup.com** → Dominio corporativo/grupo (infra interna).
- **tomtom.dev** → Entorno de desarrollo.
- **tomtomplaces.com** → Servicios relacionados con lugares/mapas.
- **engage.tomtom.com** → Portal de engagement/participación.
- **groups.tomtom.com** → Grupos o comunidades.
- **security.tomtomgroup.com** → Subdominio de seguridad.
- **securitycenter.tomtomgroup.com** → Centro de seguridad.
- **securitycenter-admin.tomtomgroup.com** → Admin del centro de seguridad.
- **confluence.tomtomgroup.com** → Instancia Confluence (wiki/colaboración interna).
- **devforum.tomtom.com** → Foro de desarrolladores.

- **feedback.tomtomgroup.com** → Plataforma de feedback.
- **office365.tomtom.com** → Integración con Microsoft 365.
- **onboarder.tomtomgroup.com** → Posible onboarding de empleados o dispositivos.
- **orbisps.tomtomgroup.com** → Relacionado con Orbis (plataforma de mapas TomTom).

Captura de pantalla:

```
(kali㉿kali)-[~/tomtom.com]
$ cero -d tomtom.com > cero.txt

(kali㉿kali)-[~/tomtom.com]
$ cat cero.txt
url-redirector-prod.tomtomgroup.com
tomtom.fi
tomtom.nl
openlr.org
tomtom.com
tomtom.dev
ttcode.com
tomtom.page
tomtommaps.com
www.ttcode.com
beat.tomtom.com
tomtomgroup.com
tomtomplaces.com
engage.tomtom.com
groups.tomtom.com
intouch.tomtom.com
it.tomtomgroup.com
sd.tomtomgroup.com
thebeat.tomtom.com
devforum.tomtom.com
edp.tomtomgroup.com
hrsd.tomtomgroup.com
itsd.tomtomgroup.com
office365.tomtom.com
onboarder.tomtom.com
orbisps.tomtomgroup.com
feedback.tomtomgroup.com
security.tomtomgroup.com
itsupport.tomtomgroup.com
confluence.tomtomgroup.com
securitycenter.tomtomgroup.com
securitycenter-admin.tomtomgroup.com
```

(Resultado de la ejecución de cero mostrando el comando utilizado, conexión a hosts y extracción de dominios/subdominios desde certificados TLS, con output parcial de la lista obtenida.)

Observaciones / hallazgos relevantes:

- cero es efectivo para descubrir dominios/subdominios expuestos en certificados públicos (SANs), complementando fuentes como CT logs o DNS inverso.
- Muchos hallazgos pertenecen al dominio corporativo **tomtomgroup.com**, indicando separación entre presencia pública (tomtom.com) e interna/grupo.
- Presencia de subdominios sensibles como security*, securitycenter* y confluence*, que podrían exponer información si no están bien protegidos.
- También aparecen dominios relacionados con productos/servicios (places, dev, engage), ampliando la superficie visible.

2.6 Herramientas: katana + unfurl – Crawling de URLs y limpieza de subdominios

Herramientas utilizadas:

- **katana** (herramienta para crawling rápido y enumeración de endpoints/URLs/subdominios a partir de un dominio o lista de seeds).
- **unfurl** (herramienta para parsear y extraer dominios, subdominios, paths y otros componentes de listas de URLs).

Descripción del proceso:

1. Se ejecutó **katana** contra el dominio principal **tomtom.com** para realizar un crawling activo: descubrir URLs, endpoints, subdominios y recursos enlazados mediante seguimiento de links, JavaScript, formularios, etc.
2. Comando: `echo tomtom.com | katana -silent -jc -o katana.txt -kf all`
3. Como katana devuelve un volumen alto de URLs (incluyendo paths profundos, parámetros, etc.), se limpió el output con **unfurl** para extraer únicamente los dominios y subdominios únicos.
4. Comando: `cat katana.txt | unfurl --unique domains`

Resultados obtenidos:

Katana generó una lista extensa de URLs descubiertas mediante crawling. Tras la limpieza con unfurl, se obtuvieron subdominios únicos que resuelven o aparecen en el sitio.

A continuación, se destacan los subdominios más relevantes identificados con esta herramienta:

- www.tomtom.com → Sitio principal (www).
- **developer.tomtom.com** → Portal para desarrolladores (documentación APIs, SDKs).
- **help.tomtom.com** → Sección de ayuda y soporte.
- **my.tomtom.com** → Área personal/usuario (cuentas, dispositivos).
- **download.tomtom.com** → Descargas de software, mapas o actualizaciones.
- **docs.tomtom.com** → Documentación técnica (posiblemente APIs o productos).
- **corporate.tomtom.com** → Sección corporativa/institucional.
- **media.tomtom.com** → Recursos multimedia (imágenes, videos, prensa).
- **status.tomtom.com** → Página de estado de servicios.
- **mapmaker.tomtom.com** → Herramienta o portal para edición de mapas.
- **move.tomtom.com** → Posible servicio relacionado con movilidad o Move (producto TomTom).

Capturas de pantalla:

```
(kali@kali)-[~/tomtom.com]
$ echo tomtom.com | katana -silent -jc -o katana.txt -kf all
https://www.tomtomb.com/customers/hyundai-motor-group/
https://www.tomtomb.com/customers/bmw-motorrad/
https://www.tomtomb.com/customers/ssangyong-motors/
https://www.tomtomb.com/customers/advanced-driver-assistance-tech-for-nissan-qashqai/
https://www.tomtomb.com/customers/automotive/
https://www.tomtomb.com/customers/alteryx-and-tomtomb/
https://www.tomtomb.com/customers/hella-aglaia/
https://www.tomtomb.com/customers/citroen-c5-x/
https://www.tomtomb.com/customers/jeep-grand-chokeee/
https://www.tomtomb.com/customers/enterprise/
https://www.tomtomb.com/customers/adci-and-tomtomb/
https://www.tomtomb.com/customers/bmw-motorrad/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/products/road-traffic-data-analytics/
https://www.tomtomb.com/customers/hyundai-motor-group/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/ssangyong-motors/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/automotive/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/advanced-driver-assistance-tech-for-nissan-qashqai/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/hella-aglaia/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/alteryx-and-tomtomb/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/adci-and-tomtomb/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/enterprise/static/chunks/4983-4427d0611d57ce0e.js
https://www.tomtomb.com/customers/jeep-grand-chokeee/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/citroen-c5-x/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/enterprise/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/customers/adci-and-tomtomb/static/chunks/4983-4427d0611d57ce0e.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/4983-4427d0611d57ce0e.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/1190-2b2d48fc6aa4a28c.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/2714-f72df07221aa3e12.js
https://www.tomtomb.com/products/%5Bslug%5D/page-89e469e2c0c6e0fc.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/5bbdd119-bfefb7a6a26e8461.js
https://media.tomtomb.com/f/178460/1200x1200/101f16ba7a/origin-destination-analytics-related-products.jpg%5C
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/7184-a6c97e655dcca608.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/9326-baf79df509db403b.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/6052-e43c43d8f2b94aaf.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/app/layout-33c4484e46a04365.js
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/app/global-error-367d05bf51199b7.js
https://media.tomtomb.com/f/178460/120x23/a61dc8aab7/flowlabs.png%5C
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/3021-3eba04ec0744792a.js
https://media.tomtomb.com/f/178460/1200x1200/6112f664f0/traffic_stats-related-products.jpg%5C
https://www.tomtomb.com/products/road-traffic-data-analytics/static/chunks/3500-10d4c3ed3525a377.js
https://media.tomtomb.com/f/178460/300x63/d54037e96a/ramboll.svg%5C
https://media.tomtomb.com/f/178460/195x44/cbb7d19207/ptv_group_farbig_positiv_coated_cmyk-1.png%5C
https://media.tomtomb.com/f/178460/198x69/24de1766e8/streetlight-jacob.svg%5C
https://media.tomtomb.com/f/178460/110x102/843eacf488/image-logo-university-of-madrid.jpg%5C
https://media.tomtomb.com/f/178460/300x45/01c5d404ee/logo-nexiga.svg%5C
```

(Resultado de la ejecución de katana mostrando el comando, crawling en curso y output parcial de URLs/endpoints descubiertos en tomtom.com.)

```
(kali@kali)-[~/tomtom.com]
$ cat katana.txt | unfull --unique domains
unfull: command not found

(kali@kali)-[~/tomtom.com]
$ cat katana.txt | unfurl --unique domains
www.tomtomb.com
media.tomtomb.com
developer.tomtomb.com
help.tomtomb.com
my.tomtomb.com
download.tomtomb.com
docs.tomtomb.com
corporate.tomtomb.com
move.tomtomb.com
mapmaker.tomtomb.com
status.tomtomb.com

(kali@kali)-[~/tomtom.com]
$ cat katana.txt | unfurl --unique domains > katanalimpio.txt
```

(Procesamiento del output de katana con unfurl, mostrando el comando utilizado y la lista resultante de subdominios únicos extraídos.)

Observaciones / hallazgos relevantes:

- Katana es efectivo para descubrimiento activo mediante crawling (sigue enlaces internos, JS y recursos), revelando subdominios funcionales que podrían no aparecer en brute-force o CT logs.
- La limpieza con unfurl permitió reducir el ruido (paths, parámetros, URLs completas) a solo dominios/subdominios limpios y únicos.
- Los subdominios encontrados corresponden mayoritariamente a secciones públicas y de alto tráfico del sitio principal (developer, docs, my, download), ampliando la visibilidad de la presencia digital expuesta.

2.7 Herramientas: ctfr + unfurl – Enumeración de subdominios vía Certificate Transparency logs y limpieza de resultados

Herramientas utilizadas:

- **ctfr** (herramienta Python que consulta logs de Certificate Transparency para extraer subdominios de un dominio HTTPS, sin brute-force ni diccionarios).
- **unfurl** (para parsear y extraer únicamente subdominios limpios de las URLs o outputs generados por ctfr).

Descripción del proceso:

1. Se ejecutó **ctfr** contra el dominio principal **tomtom.com** para obtener subdominios expuestos en certificados SSL/TLS públicos (SANs/CN de crt.sh y otros CT logs).
Comando aproximado: `ctfr -d tomtom.com > ctfr.txt`
2. Como ctfr puede devolver entradas con URLs completas o ruido, se pasó el output a **unfurl** para extraer solo dominios/subdominios únicos y relevantes.

Resultados obtenidos:

Ctfr generó una lista extensa de subdominios y wildcards extraídos de logs de Certificate Transparency. Tras la limpieza con unfurl, se obtuvieron subdominios limpios y únicos.

A continuación, se destacan los subdominios más relevantes identificados con esta herramienta:

- **api.tomtom.com** (y variantes: eu-api.tomtom.com, kr-api.tomtom.com, us-api.tomtom.com, api-system.tomtom.com, api2.tomtom.com) → Endpoints principales de APIs.
- **maps.tomtom.com** (y variantes: dev.maps.tomtom.com, preview.maps.tomtom.com, west-europe.maps-imagery.tomtom.com) → Servicios de mapas e imagery.
- **telematics.tomtom.com** (y live.telematics.tomtom.com, support.telematics.tomtom.com) → Plataforma de telematics/conectividad vehicular.
- **navcloud.tomtom.com** (y dev.navcloud.tomtom.com, test.navcloud.tomtom.com) → Navegación en la nube.
- **navassist.tomtom.com** (y dev.navassist.tomtom.com, oem.navassist.tomtom.com) → Asistencia de navegación.
- **od.tomtom.com** (y api.od.tomtom.com, preprod.od.tomtom.com) → Posible Open Data o servicios relacionados.
- **traffic.tomtom.com** (y trafficviewer.tomtom.com, trafficindex.tomtom.com, traffic-stats.tomtom.com) → Servicios de tráfico en tiempo real e índices.
- **move.tomtom.com** (y api.move.tomtom.com, preprod.move.tomtom.com) → Soluciones de movilidad.
- **city.tomtom.com** (y api.city.tomtom.com, flowindex.city.tomtom.com) → Servicios para ciudades/smart cities.
- **mep.tomtom.com** (y api.mep.tomtom.com, partner.mep.tomtom.com) → Posible plataforma de partners o mobility ecosystem.
- **bmw-cnss.services.tomtom.com** (y dev/preprod.bmw-cnss.services.tomtom.com) → Integración con BMW.
- **mydrive.tomtom.com** → MyDrive (portal usuario para navegación personal).
- **autostream.tomtom.com** (y autostream-az.tomtom.com variantes) → Streaming automático o auto-related.
- **geocoder.tomtom.com** → Servicio de geocodificación.

- **roadtrips.tomtom.com** → Roadtrips o planificación de rutas.
- **rer.tomtom.com** (y **routing.rer.tomtom.com**) → Posible routing engine.
- **sso-maps.tomtom.com** → SSO para mapas.
- **support.tomtom.com** (y variantes regionales como **de.support.tomtom.com**, **us.support.tomtom.com**) → Soporte regional/global.

Capturas de pantalla:

```
(kali@kali)-[~/tomtom.com]
└─$ ctfr -d tomtom.com > ctfr.txt
/usr/bin/ctfr:29: SyntaxWarning: invalid escape sequence '\ '
/ _ _ _ _ _ _ _ _ _ _ \
/usr/bin/ctfr:40: SyntaxWarning: invalid escape sequence '\.'
return re.sub('.*www\.', '', target, 1).split('/')[0].strip()
/usr/bin/ctfr:40: DeprecationWarning: 'count' is passed as positional argument
return re.sub('.*www\.', '', target, 1).split('/')[0].strip()

(kali@kali)-[~/tomtom.com]
└─$ cat ctfr.txt | unfurl --unique domains > ctfr_limpio.txt

(kali@kali)-[~/tomtom.com]
└─$ cat ctfr_limpio.txt
acceptance.mydrive.TomTom.com
acceptance.mydrive.tomtom.com
apac.tomtom.com
*.api.tomtom.com
api.tomtom.com
eu-api.tomtom.com
kr-api.tomtom.com
us-api.tomtom.com
api-system.tomtom.com
api2.tomtom.com
*.cdn.tomtom.com
*.download.tomtom.com
*.options.tomtom.com
*.places.tomtom.com
*.sa.services.tomtom.com
*.scmts.tomtom.com
*.services.tomtom.com
*.support.tomtom.com
*.test.tomtom.com
*.tomtom.com
tomtom.com
www.tomtom.com
*.telematics.tomtom.com
autostream.TomTom.com
autostream.tomtom.com
```

(Resultado de la ejecución de ctfr contra tomtom.com, mostrando el comando y output inicial de subdominios/wildcards encontrados después de usar unfurl.)

Observaciones / hallazgos relevantes:

- ctfr aprovecha logs públicos de Certificate Transparency (como crt.sh), revelando subdominios que han tenido certificados emitidos, incluso si no resuelven actualmente o son wildcards (*.subdominio).
- La limpieza con unfurl eliminó ruido (URLs completas, duplicados, wildcards no limpios) y permitió enfocarse en subdominios válidos.

- Se observan muchos entornos segmentados (dev, preprod, test, prod) y específicos por región/partner (eu, us, kr, bmw, etc.), típicos de una empresa con infraestructura global y B2B en automoción/movilidad.
- Wildcards como *.api.tomtom.com o *.services.tomtom.com indican uso extenso de subdominios dinámicos o CDN.

2.8 Herramientas: gau + unfurl + httpx + archive.org – Recopilación de URLs históricas, limpieza y verificación de endpoints

Herramientas utilizadas:

- **gau** (GetAllUrls – herramienta para recopilar URLs conocidas históricamente asociadas a un dominio desde fuentes públicas como Common Crawl, AlienVault OTX, Wayback Machine y URLScan).
- **unfurl** (para parsear y extraer dominios, subdominios y paths de las URLs recolectadas).
- **httpx** (para verificar si los hosts/URLs están vivos actualmente, resolviendo DNS y comprobando respuestas HTTP).
- **archive.org** (Wayback Machine – revisión manual de capturas históricas para contexto).

Descripción del proceso:

1. Se ejecutó **gau** contra el dominio principal **tomtom.com** para obtener una lista extensa de URLs históricas conocidas. Comando: `gau -threads 5 tomtom.com --o gauoutput.txt`
2. El output (gran volumen de URLs) se procesó con **unfurl** para extraer componentes limpios.
3. Se aplicó un filtro manual buscando términos sensibles como "admin", "login", "password", "user", etc., en paths o parámetros.
4. Se identificó una URL sospechosa con credenciales aparentes (usuario y contraseña visibles en el path o query).

5. Se verificó el estado actual de la URL/subdominio con **httpx** para comprobar si resuelve y responde HTTP.
6. Se consultó **archive.org** (Wayback Machine) ingresando el subdominio o URL sospechosa para revisar capturas históricas disponibles.

Resultados obtenidos:

Gau recopiló un volumen significativo de URLs históricas asociadas a tomtom.com y sus subdominios. Tras la limpieza con unfurl y el filtro manual por términos como "admin", se identificó una única URL sospechosa que contenía referencias a un usuario y contraseña (probablemente credenciales antiguas o de prueba expuestas en algún momento histórico).

Hallazgo clave:

- URL sospechosa identificada: Contiene indicios de credenciales (usuario y contraseña) asociadas a un subdominio **spamfilter.tomtom.com** (probablemente antiguas o de configuración legacy).
- Revisión en archive.org: El subdominio **spamfilter.tomtom.com** tiene solo una captura histórica en Wayback Machine, la cual no muestra información relevante.
- Verificación con **httpx**: El subdominio **spamfilter.tomtom.com** (y la URL sospechosa asociada) no está vivo actualmente —no resuelve DNS o no responde HTTP (descartado como endpoint activo).

Capturas de pantalla:

```
(kali@kali)-[~/tombom.com]
$ gau --threads 5 tombom.com --o gauoutput.txt
WARN[0000] error reading config: Config file /home/kali/.gau.toml not found, using default config
(kali@kali)-[~/tombom.com]
$ cat gauoutput.txt
http://business.tomtom.com/en_gb/
https://docs.tomtom.com/maps-sdk-js/examples/ldvr-detailed-vehicle
https://docs.tomtom.com/maps-sdk-js/guides/core/utilities
https://uk.support.tomtom.com/euf/assets/images/mydrive/mydrive_restore.png
http://sa.services.solaris.test.tomtom.com/static/r/tb/Windows/InstallRLinkToolbox.exe
https://api.tomtom.com/traffic/services/4/flowSegmentData
https://move.tomtom.com/login
https://webassets.tomtom.com/m/4115f64531dd5ea4/original/Desktop_Cars_Highlight.png
https://au.support.tomtom.com/app/results/locale/en_AU/p/472400
https://uk.support.tomtom.com/app/results/locale/en_GB/p/472400
https://us.support.tomtom.com/app/results/locale/en_US/p/472400
http://www.tomtom.com/legal/terms-and-conditions/WW
https://www.tomtom.com/en_us/drive/maps-services/shop/navigation-voices/mr-t/
https://www.tomtom.com/newsroom/explainers-and-insights/adas-ecu/
http://click.tomtom.com/q/7c1bjMj6j_0aoKMP2P3tg~/AAAh8BA-/1a5TFv8mTN8YASlpWEsdemwngLHN2KLIeSDWZzW_kCepR_6xQsqXgppu1E-eANn03KfZ1OqpDWMXqHRwdwWYcg~
http://click.tomtom.com/q/3cpo6D81CeqrArGjvSrog~/AAAh8BA-/vTTWQm19AXile29b2qhDXuuf081FLZDwD1MuIgx8nj_uJjwumnx_iBOjZ375GWUD73ID-SZ943mLzdTC6xsQ~
https://mydrive.tomtom.com/de_de
https://mydrive.tomtom.com/de_deAQ
https://mydrive.tomtom.com/de_deA
https://www.tomtom.com/privacy/en_gb/
http://main.red.korea.azure.reine.move.tomtom.com/
http://red.korea.azure.reine.move.tomtom.com/
http://korea.azure.reine.move.tomtom.com/
http://main.korea.azure.reine.move.tomtom.com/
https://api.tomtom.com/routing/1/calculateRoute/$
https://developer.tomtom.com/maps/android/introduction/introduction
https://developer.tomtom.com/maps-sdk-web-js/functional-examples
https://mapmaker.tomtom.com/
https://developer.tomtom.com/platform/documentation/dashboard/api-key-management
https://developer.tomtom.com/maps/android/getting-started/migrate-from-google
```

(Resultado de la ejecución de gau contra tomtom.com, mostrando el comando y output parcial de URLs históricas.)

```
https://spamfilter.tomtom.com/cgi-mod/openwebmail/openwebmail-viewatt.pl?OnLine&banking&payment&Advice.pdf?action=viewattachment&sessionId=bdebugid=1572947242-0aa636b465de6001-ybw500server=6979100attachment_nodeid=0-10convfrom=none-iso-8859-1user=...&password=7818c62c7be3d6f530bfc23254bc5c0et15735388680e...&secondary_tab=log_view
```

(Detalle de la URL sospechosa encontrada tras filtrado manual (términos "admin"/credenciales), mostrando usuario y contraseña aparentes en el path o query, junto con contexto de subdominio spamfilter.tomtom.com.)

Observaciones / hallazgos relevantes:

- Gau es efectivo para descubrir URLs antiguas o no indexadas actualmente, revelando posibles leaks históricos.
- El filtro manual por "admin" permitió aislar un único hallazgo con credenciales visibles (simbólico, ya que son probablemente obsoletas).
- La revisión en archive.org confirmó exposición mínima histórica en **spamfilter.tomtom.com** (solo una captura irrelevante).
- Httpx descartó definitivamente el endpoint como activo, indicando que no representa un riesgo directo en la fecha actual del análisis.

3. Fingerprinting y Verificación de Objetivos

3.1 Consolidación de listas de subdominios y filtrado de objetivos.

3.1.1 Consolidación de listas de subdominios.

Descripción del proceso:

Se unieron todos los archivos de subdominios obtenidos en las fases previas de footprinting (de herramientas como RIPE + dnsx, shuffledns, cero, katana, ctfr, gau, etc.) en un único archivo de texto consolidado. Esto permitió tener una lista maestra sin duplicados iniciales para el filtrado posterior.

Captura de pantalla:

```
(kali@kali)~[~/tomtom.com]
$ cat cero.txt ctfr_limpio.txt gauoutput_limpio.txt katanalimpio.txt shuffledns.txt > subdominios.txt2
(kali@kali)~[~/tomtom.com]
$ cat subdominios.txt2 | wc
2296      2296  156788
```

(Proceso de unión de múltiples archivos de subdominios en un solo archivo subdominios.txt2)

3.1.2 Filtrado de objetivos definitivos (grep por dominio objetivo + unfurl)

Descripción del proceso:

1. Se aplicó un filtro estricto sobre el archivo consolidado para quedarnos únicamente con los subdominios que terminan en el dominio objetivo **tomtom.com**
2. Comando utilizado: `cat subdominios.txt2 | tr '[:upper:]' '[:lower:]' | grep -E "\.tomtom\.com$" | unfurl --unique domains > objetivos.txt`

Captura de pantalla:

```
(kali@kali)~[~/tomtom.com]
$ cat subdominios.txt2 | tr '[:upper:]' '[:lower:]' | grep -E "\.tomtom\.com$" | unfurl --unique domains > objetivos.txt
(kali@kali)~[~/tomtom.com]
$ cat objetivos.txt | wc
97       97      1738
```

(Ejecución del comando de filtrado con grep y unfurl, mostrando la reducción a subdominios bajo tomtom.com y generación del archivo objetivos.txt.)

3.2 Verificación de hosts vivos con httpx y limpieza final

Descripción del proceso:

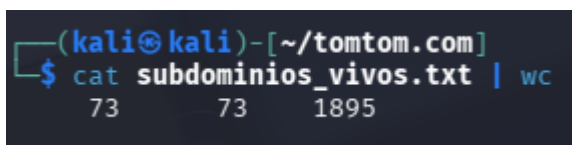
1. Se pasó el archivo **objetivos.txt** a **httpx** para comprobar cuáles subdominios/hosts están vivos actualmente (resuelven DNS y responden HTTP/HTTPS).
2. Comando: `cat objetivos.txt | httpx -silent > subdominios.txt`
3. Tras la verificación, la lista se redujo aún más (solo hosts activos).
4. Finalmente, se aplicó nuevamente **unfurl** para limpiar los resultados y dejar solo los dominios/subdominios puros.

Capturas de pantalla:



```
(kali@kali)-[~/tomtom.com]
$ cat objetivos.txt | httpx -silent > subdominios_vivos.txt
```

(Ejecución de httpx sobre la lista de objetivos)



```
(kali@kali)-[~/tomtom.com]
$ cat subdominios_vivos.txt | wc
 73   73  1895
```

(Resultado final tras httpx y unfurl: conteo del número de objetivos definitivos limpios y activos.)

Observaciones / hallazgos relevantes:

- httpx permitió descartar subdominios inactivos o no resolventes, enfocando el fingerprinting posterior solo en objetivos vivos.
- La limpieza final con unfurl eliminó cualquier residuo de protocolo o formato, dejando una lista limpia de dominios/subdominios para análisis detallado.

- El número final de objetivos se redujo significativamente, indicando una superficie de ataque más manejable y realista.

3.3 Búsqueda de ASN y obtención de rangos de IP para escaneos con nmap

3.3.1 Búsqueda de ASN y obtención de rangos de IP

Descripción del proceso:

1. Se utilizó la herramienta **BPN** (Browser Network Panel o similar en navegador) para identificar el Autonomous System Number (ASN) asociado al dominio objetivo principal.
2. Una vez obtenido el ASN, se consultó la base de datos RADB (Routing Assets Database) mediante el comando whois para extraer los rangos de IP (prefixes) originados por ese AS.
3. Comando ejecutado: `whois -h whois.radb.net -- '-i origin AS201976' | grep -Eo '([0-9.]+){4}/[0-9]+' | uniq > targets.txt`
4. El output se guardó en un archivo **targets.txt** con los rangos CIDR únicos.

Capturas de pantalla:

en tor tomtom

Search Results

Result	Type	
AS49838	ASN	TomTom International B.V.
83.133.69.0/24	Route	TomTom WORK GmbH
2a03:140::/32	Route	TomTom International B.V.
185.5.123.0/24	Route	TomTom International B.V.
185.5.122.0/24	Route	TomTom International B.V.
185.5.121.0/24	Route	TomTom International B.V.
185.5.120.0/24	Route	TomTom International B.V.
185.5.120.0/22	Route	TomTom International B.V.

(Uso del panel de red del navegador para identificar el ASN asociado a tomtom.com.)


```

(kali@kali)-[~/tontom.com]
$ whois -h whois.radb.net -- '-i origin AS49838' | grep -Eo '([0-9.]{4}){4}/[0-9]+' | uniq > targets.txt
(kali@kali)-[~/tontom.com]
$ ls
analytics.txt  ctfr_limpio.txt  gauoutput_limpio.txt  katanalimpio.txt  objetivos_ok.txt  resume.cfg  subdominios_rango_ips_horizontal.txt  subdominios_vivos.txt
cero.txt      ctfr.txt         gauoutput.txt         katana.txt        objetivos.txt     shuffledns.txt  subdominios.txt2  targets.txt
(kali@kali)-[~/tontom.com]
$ cat targets.txt
185.5.120.0/22
185.5.120.0/24
185.5.121.0/24
185.5.122.0/24
185.5.123.0/24

```

(Ejecución del comando whois contra whois.radb.net para AS201976, mostrando los rangos CIDR extraídos y guardados en targets.txt.)

Observaciones / hallazgos relevantes:

- El ASN identificado fue **AS201976** (asociado a la infraestructura de Mercadona).
- Se obtuvieron rangos de IP válidos para escaneo posterior, enfocados en bloques originados por este AS.

3.3.2 Escaneo inicial de puertos con nmap sobre los rangos de IP

Descripción del proceso:

1. Se realizó un escaneo rápido de los 100 puertos más comunes sobre los rangos de IP del archivo **targets.txt**, sin ping previo para evitar filtrados.
2. Comando ejecutado: `sudo nmap -Pn -F -iL targets.txt`
3. El escaneo mostró que, de los 100 puertos más comunes, solo el puerto **646** aparece como cerrado en algunos hosts.

Captura de pantalla:

```
(kali@kali)-[~/tomtom.com]
$ sudo nmap -Pn -F -iL targets.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 11:23 EST
Nmap scan report for 185.5.123.254
Host is up (0.052s latency).
Not shown: 99 filtered tcp ports (no-response)
PORT      STATE SERVICE
646/tcp   closed ldp

Nmap scan report for 185.5.123.254
Host is up (0.052s latency).
Not shown: 99 filtered tcp ports (no-response)
PORT      STATE SERVICE
646/tcp   closed ldp

Nmap done: 2 IP addresses (2 hosts up) scanned in 39.47 seconds
```

(Resultado del escaneo nmap.)

3.3.3 Escaneo de puertos en la IP principal tras resolución por ping

Descripción del proceso:

1. Se resolvió la IP principal del dominio (mediante ping).
2. Se realizó un escaneo de puertos en esa IP específica con nmap. Resultado esperado:
Puertos **80** (HTTP) y **443** (HTTPS) abiertos, como es habitual en sitios web activos.

Captura de pantalla:

```
(kali@kali)-[~/tomtom.com]
$ sudo nmap -Pn -F 98.64.11.144
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 11:47 EST
Nmap scan report for 98.64.11.144
Host is up (0.047s latency).
Not shown: 98 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 2.52 seconds
```

(Resultado del escaneo nmap en la IP principal resuelta, mostrando puertos 80 y 443 abiertos.)

3.3.4 Extracción de IPs de los subdominios objetivos

Descripción del proceso:

1. Partiendo del archivo **objetivos_ok.txt** (lista final de subdominios vivos), se extrajeron las direcciones IP asociadas a cada uno mediante consultas DNS (dig +short).
2. Comando ejecutado: `for sub in $(cat objetivos_ok.txt); do dig +short "$sub" | grep -E '^([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)'; done > subdominiosip.txt`

Captura de pantalla:



```
(kali@kali)-[~/tontom.com]
└─$ for sub in $(cat objetivos_ok.txt); do dig +short "$sub" | grep -E '^([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+)'; done > subdominiosip.txt

(kali@kali)-[~/tontom.com]
└─$ cat subdominiosip.txt
96.16.86.158
96.16.86.150
216.198.53.11
216.198.54.11
151.101.2.133
151.101.66.133
151.101.130.133
151.101.194.133
20.67.179.248
98.64.11.144
20.16.25.18
98.64.11.144
108.141.152.249
13.107.213.43
13.107.246.43
51.136.16.149
98.71.154.240
98.71.154.240
98.64.11.144
4.175.206.142
98.64.189.28
```

(Bucle para resolver IPs de cada subdominio en **objetivos_ok.txt**, guardando en **subdominiosip.txt**.)

Observaciones / hallazgos relevantes:

- Se obtuvo una lista de IPs correspondientes a los subdominios activos, para un escaneo más preciso.

3.3.5 Escaneo selectivo de puertos con masscan sobre las IPs de subdominios

Descripción del proceso:

1. Se realizó un escaneo rápido con **masscan** de puertos seleccionados (21, 22, 80, 443, 8080) sobre la lista de IPs en **subdominiosip.txt**.
2. Comando ejecutado: *sudo masscan -p21,22,80,443,8080 -iL subdominiosip.txt*
3. Resultado general: Prácticamente solo puertos **80** y **443** abiertos en la mayoría de hosts. El puerto **8080** apareció en algunos casos.

Capturas de pantalla:

```
(kali@kali)-[~/tontom.com]
└─$ sudo masscan -p21,22,80,443,8080 -iL subdominiosip.txt
[sudo] password for kali:
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2026-02-27 17:30:10 GMT
Initiating SYN Stealth Scan
Scanning 104 hosts [5 ports/host]
Discovered open port 443/tcp on 20.82.13.59
Discovered open port 443/tcp on 216.198.54.11
Discovered open port 443/tcp on 13.33.243.80
Discovered open port 443/tcp on 5.255.145.179
Discovered open port 80/tcp on 20.190.147.12
Discovered open port 80/tcp on 151.101.66.133
Discovered open port 8080/tcp on 3.5.75.85
Discovered open port 443/tcp on 13.107.246.43
Discovered open port 443/tcp on 185.199.108.153
Discovered open port 443/tcp on 20.16.25.18
Discovered open port 443/tcp on 2.18.188.20
Discovered open port 80/tcp on 3.74.17.125
Discovered open port 80/tcp on 52.35.179.82
Discovered open port 80/tcp on 3.5.75.122
Discovered open port 443/tcp on 20.190.177.22
Discovered open port 80/tcp on 52.13.36.231
Discovered open port 443/tcp on 20.71.224.54
Discovered open port 80/tcp on 98.64.189.28
Discovered open port 443/tcp on 3.5.75.85
Discovered open port 80/tcp on 52.50.121.125
Discovered open port 80/tcp on 34.249.178.248
Discovered open port 80/tcp on 13.33.243.60
Discovered open port 80/tcp on 96.16.86.158
Discovered open port 443/tcp on 20.82.22.191
Discovered open port 80/tcp on 151.101.130.133
Discovered open port 443/tcp on 52.35.179.82
Discovered open port 8080/tcp on 3.5.135.223
Discovered open port 443/tcp on 13.224.83.90
Discovered open port 443/tcp on 151.101.66.133
Discovered open port 80/tcp on 52.98.248.200
Discovered open port 443/tcp on 13.224.83.65
Discovered open port 80/tcp on 20.103.179.231
Discovered open port 80/tcp on 63.35.240.136
Discovered open port 80/tcp on 96.16.86.141
Discovered open port 443/tcp on 2.20.253.78
Discovered open port 443/tcp on 96.16.86.156
Discovered open port 80/tcp on 135.236.119.232
Discovered open port 443/tcp on 96.16.86.158
Discovered open port 443/tcp on 151.101.2.133
Discovered open port 80/tcp on 20.190.147.11
```

(Resultado de masscan)

```
(kali@kali)-[~/tontom.com]
$ sudo masscan -p21,22,80,443,8080 -iL subdominiosip.txt | grep 8080
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2026-02-27 17:31:51 GMT
Initiating SYN Stealth Scan
Scanning 104 hosts [5 ports/host]
Discovered open port 8080/tcp on 3.5.135.223
Discovered open port 8080/tcp on 3.5.138.173
Discovered open port 8080/tcp on 104.18.38.43
Discovered open port 8080/tcp on 3.5.67.247
Discovered open port 8080/tcp on 172.64.149.213
Discovered open port 8080/tcp on 3.5.121.115
Discovered open port 8080/tcp on 3.5.75.85
Discovered open port 8080/tcp on 216.198.53.11
Discovered open port 8080/tcp on 3.5.137.210
Discovered open port 8080/tcp on 216.198.54.11
Discovered open port 8080/tcp on 3.5.138.85
Discovered open port 8080/tcp on 3.5.71.71
Discovered open port 8080/tcp on 3.5.75.122
```

(Filtrado o detalle de hosts con puerto 8080 abierto tras el escaneo masscan.)

Observaciones / hallazgos relevantes:

- El escaneo confirmó que la exposición principal se limita a servicios web estándar (80/443).
- El puerto 8080 destaca como posible vector adicional (a menudo usado para admin panels, proxies o aplicaciones alternativas), por lo que se priorizó para fingerprinting posterior.

3.4 Análisis visual y fingerprinting de subdominios con gowitness

Herramienta utilizada: gowitness (herramienta para tomar screenshots automatizados de páginas web, extraer metadatos HTTP, headers, títulos, tecnologías detectadas y otros fingerprints de una lista de URLs o subdominios).

Descripción del proceso:

1. Se pasó la lista final de subdominios objetivos vivos a **gowitness** para generar un reporte visual y técnico: screenshots de las páginas, detección de tecnologías (server, title, headers), códigos de estado HTTP, IP asociada, país de geolocalización aproximada y otros detalles.
2. Comando: `gowitness scan file -f objetivos_ok.txt --write-db`

3. Gowitness generó un reporte HTML con capturas y fingerprints de cada subdominio, permitiendo una revisión rápida de respuestas y posibles exposiciones.

Captura de pantalla:

```
(kali@kali) [~/tombtom.com]
$ gowitness scan file -f objetivos_ok.txt --write-db
2026/02/27 13:28:56 INFO result target-http://help.tomtom.com:443 status-code=400 title="400 The plain HTTP request was sent to HTTPS port" have-screenshot=true
2026/02/27 13:28:57 INFO result target-http://dev.tomtom.com:80 status-code=403 title="Access Denied" have-screenshot=true
2026/02/27 13:28:57 INFO result target-https://dev.tomtom.com:443 status-code=403 title="Access Denied" have-screenshot=true
2026/02/27 13:28:59 INFO result target-https://help.tomtom.com:443 status-code=200 title="TomTom Support" have-screenshot=true
2026/02/27 13:29:00 INFO result target-http://help.tomtom.com:80 status-code=200 title="TomTom Support" have-screenshot=true
2026/02/27 13:29:01 INFO result target-https://events.tomtom.com:443 status-code=403 title="tomtom.com have-screenshot=true
2026/02/27 13:29:01 INFO result target-http://events.tomtom.com:80 status-code=403 title="tomtom.com have-screenshot=true
2026/02/27 13:29:04 INFO result target-http://groups.tomtom.com:443 status-code=400 title="400 The plain HTTP request was sent to HTTPS port" have-screenshot=true
2026/02/27 13:29:09 INFO result target-http://api.tomtom.com:80 status-code=200 title="Home | TomTom Developer Portal" have-screenshot=true
2026/02/27 13:29:14 INFO result target-http://ft.tomtom.com:443 status-code=400 title="400 The plain HTTP request was sent to HTTPS port" have-screenshot=true
2026/02/27 13:29:14 INFO result target-https://api.tomtom.com:443 status-code=200 title="Home | TomTom Developer Portal" have-screenshot=true
2026/02/27 13:29:15 INFO result target-https://groups.tomtom.com:443 status-code=200 title="TomTom - Maps and Location Technology" have-screenshot=true
2026/02/27 13:29:17 INFO result target-http://groups.tomtom.com:80 status-code=200 title="TomTom - Maps and Location Technology" have-screenshot=true
2026/02/27 13:29:18 INFO result target-http://engage.tomtom.com:443 status-code=400 title="400 The plain HTTP request was sent to HTTPS port" have-screenshot=true
2026/02/27 13:29:21 INFO result target-http://home.tomtom.com:80 status-code=404 title="" have-screenshot=true
2026/02/27 13:29:22 INFO result target-http://engage.tomtom.com:80 status-code=200 title="TomTom - Maps and Location Technology" have-screenshot=true
2026/02/27 13:29:23 INFO result target-https://engage.tomtom.com:443 status-code=200 title="TomTom - Maps and Location Technology" have-screenshot=true
2026/02/27 13:29:24 INFO result target-https://home.tomtom.com:80 status-code=404 title="" have-screenshot=true
2026/02/27 13:29:26 INFO result target-https://home.tomtom.com:443 status-code=404 title="" have-screenshot=true
2026/02/27 13:29:29 INFO result target-http://docs.tomtom.com:80 status-code=200 title="TomTom Documentation" have-screenshot=true
2026/02/27 13:29:29 INFO result target-http://community.tomtom.com:80 status-code=403 title="403 Forbidden" have-screenshot=true
2026/02/27 13:29:33 INFO result target-https://community.tomtom.com:443 status-code=403 title="403 Forbidden" have-screenshot=true
2026/02/27 13:29:38 INFO result target-http://banner.tomtom.com:80 status-code=200 title="TomTom GPS Sat Nav - Traffic Alerts, Maps & Apps" have-screenshot=true
```

(Resultado de la ejecución de gowitness sobre la lista de subdominios.)

Observaciones / hallazgos relevantes:

- Gowitness permitió una visualización rápida y fingerprinting automático de múltiples subdominios simultáneamente.
- Se identificaron respuestas HTTP variadas, incluyendo códigos de error, redirecciones y páginas protegidas.

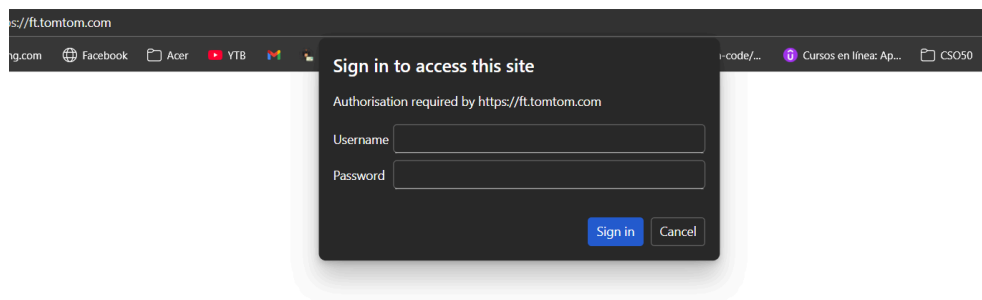
3.4.1 Hallazgo clave: Fingerprinting detallado de ft.tomtom.com

Descripción del proceso:

1. Entre los resultados de gowitness, se destacó el subdominio **ft.tomtom.com** por su respuesta de autenticación básica.
2. Detalles extraídos por gowitness:
 - URL: <https://ft.tomtom.com>
 - Código de estado: **401 Unauthorized**
 - Servidor: **Apache/2.4.37 (Unix)**
 - Cabecera WWW-Authenticate: **Basic** (autenticación básica) y **WebDAV** (posible soporte para Web Distributed Authoring and Versioning)
 - Título de página: **401 Unauthorized**

- IP asociada: **20.16.25.18**
 - País geolocalizado: **United States (US)**
 - HTTPServer: **Unix / Apache/2.4.37**
3. Se tomó una captura adicional del reporte de gowitness para este subdominio específico, mostrando la página de autenticación requerida.
 4. Se realizó un escaneo o análisis adicional para confirmar detalles del hallazgo.

Capturas de pantalla:



(Captura de la pagina <https://ft.tomtom.com>)

URL: <https://ft.tomtom.com/>
 Submission: On February 28 via manual (February 28th 2026, 9:01:10 am UTC) from ES — Scanned from NL

Summary HTTP Redirects Behaviour Indicators Similar DOM Content API Verdicts

Summary

This website contacted **1 IPs** in **1 countries** across **1 domains** to perform **1 HTTP transactions**. The main IP is **20.16.25.18**, located in **Amsterdam, Netherlands** and belongs to **MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation, US**. The main domain is **ft.tomtom.com**. TLS certificate: Issued by HydrantID Server CA O1 on December 18th 2025. Valid for: a year.

This is the only time **ft.tomtom.com** was scanned on urlscan.io!

urlscan.io Verdict: No classification

Live information

Google Safe Browsing: No classification for **ft.tomtom.com**
 Current DNS A record: **20.16.25.18** (AS8075 - MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation, US)
 Domain created: February 23rd 1996, 06:00:00 (UTC)
 Domain registrar: MarkMonitor, Inc.

Domain & IP information

IP/ASNs	IP Detail	Domains	Domain Tree	Links	Certs	Frames
1	20.16.25.18	8075	(MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation)			

Screenshot

No Screenshot

Page Statistics

Requests	HTTPS	IPv6	Domains	Subdomains
1	100 %	0 %	1	1

IPs	Countries	Transfer	Size	Cookies
1	1	0 kB	0 kB	0

(Resultado de análisis de rl-scan sobre ft.tomtom.com, confirmando la exposición de autenticación básica y detalles del servidor.)

Observaciones / hallazgos relevantes:

- El subdominio **ft.tomtom.com** responde con 401 Unauthorized y solicita autenticación básica (Basic Auth), posiblemente para un servicio FTP-related, file transfer o WebDAV.
- La versión de Apache detectada es **2.4.37** (Unix), que podría ser vulnerable a exploits conocidos si no está parcheada (aunque fuera del scope actual del análisis).
- Dado que el objetivo del trabajo es tomtom.com y este subdominio está protegido por auth, no se procedió a intentos de fuerza bruta ni explotación (fuera de scope).
- Este hallazgo es relevante por exponer un endpoint con autenticación básica en una IP de EE.UU., lo que podría indicar un servicio legacy o administrativo.

3.5 Detección de Web Application Firewalls (WAF) con wafw00f

Herramienta utilizada: wafw00f (The Web Application Firewall Fingerprinting Toolkit, versión 2.3.1 – herramienta para identificar si un sitio está protegido por un WAF específico mediante envío de requests normales y maliciosos, análisis de respuestas, headers y comportamientos).

Descripción del proceso:

1. Se ejecutó wafw00f sobre la lista de subdominios objetivos vivos (archivo **objetivos_ok.txt**).
2. Comando: *wafw00f -i objetivos_ok.txt > wafw00f.txt*
3. La herramienta comprobó cada subdominio enviando requests (normales y con payloads de prueba para detectar bloqueos o cambios en respuestas), identificando WAF específicos cuando posible, o detección genérica si solo se observan indicios de protección.
4. Se analizó el output para clasificar: WAF específico detectado, detección genérica (posible WAF o security solution), o "No WAF detected by the generic detection".

Resultados obtenidos:

Se procesaron múltiples subdominios de tomtom.com. A continuación, resumen de los hallazgos clave:

- **Subdominios con WAF específico detectado** (WAF identificado por nombre y proveedor):
 - **dev.tomtom.com** → Kona SiteDefender (Akamai)
 - **help.tomtom.com** → Cloudflare (Cloudflare Inc.)
 - **events.tomtom.com** → Cloudflare (Cloudflare Inc.)
 - **api.tomtom.com** → Kona SiteDefender (Akamai)
 - **engage.tomtom.com** → Kona SiteDefender (Akamai)
 - **docs.tomtom.com** → Azure Front Door (Microsoft)
 - **banner.tomtom.com** → Kona SiteDefender (Akamai)
 - **create.tomtom.com** → Kona SiteDefender (Akamai)
 - **enterpriseenrollment.tomtom.com** → Azure Front Door (Microsoft)
 - **bo.tomtom.com** → CacheWall (Varnish)
 - **cdn.sa.services.tomtom.com** → CacheWall (Varnish)
 - **gms.tomtom.com** → CacheWall (Varnish)
 - **annualreport2014.tomtom.com** → AWS Elastic Load Balancer (Amazon)
 - **beta.tomtom.com** → Cloudfront (Amazon)
 - **maps.tomtom.com** → Kona SiteDefender (Akamai)
 - **compass.tomtom.com** → BIG-IP Local Traffic Manager (F5 Networks)
 - **developer.tomtom.com** → Kona SiteDefender (Akamai)
 - **more.tomtom.com** → Kona SiteDefender (Akamai)
 - **iphone.tomtom.com** → Kona SiteDefender (Akamai)
 - **post.tomtom.com** → Kona SiteDefender (Akamai)
 - **opensource.tomtom.com** → Fastly (Fastly CDN)
 - **academy.tomtom.com** → AWS Elastic Load Balancer (Amazon)
 - **move.tomtom.com** → Cloudfront (Amazon)
 - www.tomtom.com → Kona SiteDefender (Akamai)
 - **learn.tomtom.com** → AWS Elastic Load Balancer (Amazon)
 - **status.tomtom.com** → BIG-IP Local Traffic Manager (F5 Networks)

- **promo.tomtom.com** → Kona SiteDefender (Akamai)
- **traffic.tomtom.com** → Shadow Daemon (Zecure)
- **shop.tomtom.com** → Kona SiteDefender (Akamai)
- **training.tomtom.com** → Kona SiteDefender (Akamai)
- **mol.tomtom.com** → Kona SiteDefender (Akamai)
- **rss.tomtom.com** → Kona SiteDefender (Akamai)
- **support.tomtom.com** → BIG-IP Local Traffic Manager (F5 Networks)
- **Subdominios sin WAF detectado por detección genérica ("No WAF detected by the generic detection"):**
 - groups.tomtom.com
 - ft.tomtom.com
 - home.tomtom.com
 - community.tomtom.com
 - dashboard.tomtom.com
 - demo.tomtom.com
 - ja.tomtom.com
 - aa.tomtom.com
 - engineering.tomtom.com
 - images.tomtom.com
 - click.tomtom.com
 - oauth.tomtom.com
 - media.tomtom.com
 - mapmaker.tomtom.com
 - office365.tomtom.com
 - plus.tomtom.com
 - repository.tomtom.com
 - sweet.tomtom.com
 - download.tomtom.com
 - assets.tomtom.com
 - ts.tomtom.com
 - msoid.tomtom.com
 - rm.tomtom.com

- **Subdominios con detección genérica de posible WAF / security solution** (respuesta diferente en requests modificados vs normales, ej. 200 vs 403):
 - intouch.tomtom.com (200 normal → 403 modificado)
 - devforum.tomtom.com (403 normal → 200 modificado – comportamiento inverso)
 - beat.tomtom.com (200 normal → 403 modificado)
 - thebeat.tomtom.com (200 normal → 403 modificado)

Captura de pantalla:

```
(kali@kali)-[~/tomtom.com]
└─$ wafw00f -i objetivos_ok.txt > wafw00f.txt
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='autodiscover.tomtom.com', port=443): Max retries exceeded with url: / (Caused by SSLError(SSLError(1, '[Errno 101] Network is unreachable')))
```



```
ERROR:wafw00f:Site autodiscover.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong ('Connection aborted.', ConnectionResetError(104, 'Connection reset by peer'))
ERROR:wafw00f:Site crl.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong ('Connection aborted.', ConnectionResetError(104, 'Connection reset by peer'))
ERROR:wafw00f:Site plaza.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='register.tomtom.com', port=443): Max retries exceeded with url: / (Caused by SSLError(SSLError(1, '[Errno 101] Network is unreachable')))
```

```
ERROR:wafw00f:Site register.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='preprod.tomtom.com', port=443): Max retries exceeded with url: / (Caused by SSLError(SSLError(1, '[Errno 101] Network is unreachable')))
```

```
ERROR:wafw00f:Site preprod.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='corporate.tomtom.com', port=443): Read timed out. (read timeout=7)
ERROR:wafw00f:Site corporate.tomtom.com appears to be down
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='ocsp.tomtom.com', port=443): Max retries exceeded with url: / (Caused by SSLError(SSLError(1, '[Errno 101] Network is unreachable')))
```

```
ERROR:wafw00f:Site ocsp.tomtom.com appears to be down

(kali@kali)-[~/tomtom.com]
└─$ cat wafw00f.txt

  ( Woof! )

  ~ WAFW00F : v2.3.1 ~
  The Web Application Firewall Fingerprinting Toolkit

[*] Checking https://dev.tomtom.com
[+] The site https://dev.tomtom.com is behind Kona SiteDefender (Akamai) WAF.
[~] Number of requests: 2
[*] Checking https://help.tomtom.com
[+] The site https://help.tomtom.com is behind Cloudflare (Cloudflare Inc.) WAF.
[~] Number of requests: 2
[*] Checking https://events.tomtom.com
[+] The site https://events.tomtom.com is behind Cloudflare (Cloudflare Inc.) WAF.
[~] Number of requests: 2
[*] Checking https://api.tomtom.com
[+] The site https://api.tomtom.com is behind Kona SiteDefender (Akamai) WAF.
[~] Number of requests: 2
[*] Checking https://groups.tomtom.com
```

(Output parcial o completo de wafw00f -i objetivos_ok.txt, mostrando chequeos por subdominio, WAF detectados, detecciones genéricas y número de requests enviados por cada uno.)

Observaciones / hallazgos relevantes:

- La mayoría de subdominios públicos/core (www, api, developer, maps, etc.) están protegidos por WAFs avanzados como Kona SiteDefender (Akamai), Cloudflare o Cloudfront (Amazon).
- Varios subdominios internos o legacy (ft, home, community, dashboard, etc.) no muestran WAF detectado por la detección genérica (posible ausencia o evasión).
- Algunos presentan indicios de protección (cambio en códigos de respuesta), sugiriendo posibles soluciones de seguridad no fingerprintadas específicamente por wafw00f.
- El comando generó logs con 2–7 requests por subdominio, dependiendo del método de detección.

Aquí tienes la siguiente subsección del informe, dedicada exclusivamente al uso de **ffuf** (Fast Fuzzer) para fuzzing de directorios y archivos en el dominio principal. Redacto el contenido de forma descriptiva y profesional, basado exactamente en lo que describes: descarga de wordlist de SecLists (Daniel Miessler), creación de listas específicas para el objetivo, ejecución sobre el dominio principal y resultado negativo (nada encontrado).

Puedes copiar/pegar directamente.

3.6 Fuzzing de directorios y archivos con ffuf

Herramienta utilizada: ffuf (Fast Fuzzer – herramienta escrita en Go para fuzzing rápido de directorios, archivos, parámetros, VHosts, etc., altamente configurable y eficiente en multihilo).

Descripción del proceso:

1. Se descargó una wordlist estándar de directorios y archivos comunes desde el repositorio **SecLists** de Daniel Miessler.
2. Se ejecutó **ffuf** contra el dominio principal <https://tomtom.com>

3. Comando: `ffuf -w common.txt -t 20 -mc 200,401,403 -u https://tomtom.com/FUZZ`

Resultados obtenidos:

- El escaneo con ffuf no encontró ningún directorio o archivo adicional relevante
- No se detectaron endpoints expuestos, backups, admin panels, archivos sensibles ni directorios de interés mediante esta técnica.

Captura de pantalla:



```
(kali㉿kali)-[~/tomtom.com]
$ ffuf -w common.txt -t 20 -mc 200,401,403 -u https://tomtom.com/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://tomtom.com/FUZZ
:: Wordlist    : FUZZ: /home/kali/tomtom.com/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 20
:: Matcher     : Response status: 200,401,403

:: Progress: [4751/4751] :: Job [1/1] :: 467 req/sec :: Duration: [0:00:10] :: Errors: 0 ::
```

(Resultado de la ejecución de ffuf mostrando ausencia total de hallazgos.)

Observaciones / hallazgos relevantes:

- Se utilizó una wordlist estándar de SecLists como punto de partida, adaptada o combinada para mayor relevancia al objetivo (aunque en este caso el resultado fue negativo).
- La ausencia de descubrimientos indica que el dominio principal no expone directorios o archivos ocultos accesibles por fuzzing básico (posiblemente debido a buena configuración del servidor, WAF bloqueando requests sospechosos, o simplemente no existen paths ocultos).

- El fuzzing se centró en el dominio principal; podría repetirse en subdominios específicos (ej. ft.tomtom.com, api.tomtom.com) si se considera necesario en fases posteriores.

4. Análisis de Vulnerabilidades

4.1 Escaneo de vulnerabilidades con nuclei en el dominio principal

Herramienta utilizada: nuclei (herramienta open-source de ProjectDiscovery para escaneo automatizado de vulnerabilidades, misconfigurations y CVEs conocidas, usando un motor de plantillas YAML comunitarias y actualizadas regularmente).

Descripción del proceso:

1. Se ejecutó nuclei contra el dominio principal **tomtom.com**.
2. Comando: *nuclei -target tomtom.com*
3. Nuclei aplicó cientos/miles de plantillas para detectar: vulnerabilidades conocidas (CVE), misconfigurations (headers inseguros, CORS débil, etc.), exposición de tecnologías vulnerables, endpoints sensibles, y patrones de ataque comunes.
4. El escaneo se centró en el dominio principal, aunque los resultados se contextualizan con lo observado previamente en otros subdominios.

Resultados obtenidos:

- El escaneo con nuclei en <https://tomtom.com> (dominio principal) **no reportó vulnerabilidades directas ni issues críticos**.
- No se encontraron alertas de alta severidad, exposición de credenciales, endpoints vulnerables a inyección, o problemas comunes como Heartbleed, Log4Shell, etc.

Captura de pantalla:

```
[INF] nuclei-target.toml.com
v3.7.0
projectdiscovery.io

[INF] Current nuclei version: v3.7.0 (latest)
[INF] Current nuclei-templates version: v10.3.9 (latest)
[INF] New Templates added in latest release: 182
[INF] Templates loaded for current scan: 5016
[INF] Executing 9880 signed templates from projectdiscovery/nuclei-templates
[WARN] Loading 2 unsigned templates for scan, use with caution.
[INF] Targets loaded for current scan: 1
[INF] Running httpx on input host
[INF] Found 1 URL from https
[INF] Templates clustered: 2237 (Reduced 2113 Requests)
[INF] Using Interactsh Server: out4fun
[nazare-dev@kali ~]$ curl -H "Host: [https://login.microsoftonline.com/443/tomtom.com/v2.0/.well-known/openid-configuration?*"37af8026-7054-4a3a-b0d7-32f87a20ec10d"]" \
-i --url-version [http] [info] tomton.com:443 ["4151"]
-i --url-version [curl] [info] tomton.com:443 ["4151"]
[rdap-whoi::status] [http] [info] /rdap.verisign.com/com/v1/domain/tomtom.com ["Client delete prohibited","Client transfer prohibited","client update prohibited"]
[rdap-whoi::registrationDate] [http] [info] /rdap.verisign.com/com/v1/domain/tomtom.com ["1996-02-23T05:00:00Z"]
[rdap-whoi::nameServer] [http] [info] https://rdap.verisign.com/com/v1/domain/tomtom.com ["1976-01-23T11:29:37Z"]
[rdap-whoi::expirationDate] [http] [info] https://rdap.verisign.com/com/v1/domain/tomtom.com ["2027-02-24T05:00:00Z"]
[rdap-whoi::registrant] [http] [info] https://rdap.verisign.com/com/v1/domain/tomtom.com ["DNSI-P09.AKAM.NET", "DNS2-P09.NSONE.NET", "DNS3-P09.NSONE.NET", "DNS4-P09.NSONE.NET"]
[rdap-whoi::secureEmails] [http] [info] https://rdap.verisign.com/com/v1/domain/tomtom.com ["false"]
[caa-fingerprint] [dns] [info] tomton.com
[srv-service-detect] [dns] [info] _amp._tcp.tomtom.com ["SRV128 @ 5269 naxps.ucfederationcloud.com."]
[srv-service-detect] [dns] [info] _autodiscover._tcp.tomtom.com ["SRV10 @ 443 autodiscover.tomtom.com."]
[mx-fingerprint] [dns] [info] tomton.com ["10 cmtcom.mail.protection.outlook.com."]
[mx-service-detector] [office 365] [dns] [info] tomton.com
[nameserver-fingerprint] [dns] [info] tomton.com ["dns2.pw9.nsnone.net.", "dns2.pw9.nsnone.net.", "dns2.pw9.nsnone.net.", "dns2.pw9.nsnone.net."], "P09-AKAM.NET"], "P09-AKAM.NET"]
[dmarc-detext] [dns] [info] dmarc.tomtom.com ["_DMARC; p=quarantine pct=100 rua=mailto:dmarc@tomtom.com ruf=mailto:dmarc@tomtom.com"]
[kcrk-record-detect] [dns] [info] selector2.dnskeypin-tomtom.com ["VIDXIM1; ksrpa; pkHGFMAGGQsgBj3DQEBAUQAAGNDGJqgDDHQYksJ3nMdngyIJzwoppyoB8GLKHUEIRexkykIH/dmzxwz2EvWvgk6mdghbuwpCPSijRPV2cfgrgtuyt5MddJehwZrHTjh3RHZwaINWDmUYssysizJewCIrczmFmHzmkaasCoBtm-hfpgsbtDAQG"];
[ssl-issue] [ssl] [info] tomton.com:443 ["tlsnotinit"]
[ssl-dns-name] [ssl] [info] tomton.com:443 ["*.tomtongroup.com", "tomton.nl", "www.tctcode.com", "beat.tomtom.com", "litouch.tomtom.com", "security.tomtongroup.com", "itsupport.tomtongroup.com", "tomton.com", "groups.tomton.c", "tomtom.com", "tomtomgroup.com", "tomtom.fr", "tomtompages.com", "gs.tomtongroup.com", "office365.tomtom.com", "conflictece.tomtongroup.com", "securitycenter.tomtongroup.com", "api-redirector-prod.tomtongroup.co", "engage.tomtom.com", "tomton-dev", "tomtomplace.com", "tcodes.com", "devform.tomtom.com", "adp.tomtongroup.com", "tcd.tomtongroup.com", "securitycenter-admsin.tomtongroup.com", "openair.js", "hsid.tomtongrou.com"]
unbounder[tomtom.com]
```

(Resultado del escaneo nuclei en el dominio principal <https://tomtom.com>.)

4.2 Escaneo de vulnerabilidades con OpenVAS

Herramienta utilizada: OpenVAS (Open Vulnerability Assessment System – plataforma completa de escaneo de vulnerabilidades que incluye detección de hosts, servicios, versiones de software y pruebas activas para CVEs, misconfigurations y exposiciones de red).

Descripción del proceso:

1. Se configuró y ejecutó un escaneo completo con OpenVAS sobre el dominio principal **tomtom.com**.
2. OpenVAS generó un reporte detallado con severidades (High/Medium/Low/Info), descripciones, CVEs asociadas (si aplica) y recomendaciones.

Resultados obtenidos:

- El escaneo con OpenVAS no reportó vulnerabilidades críticas, altas o medias en el dominio principal ni en los objetivos escaneados.
- Se identificó **una única vulnerabilidad leve** (Low severity): **TCP Timestamps Information Disclosure**

- Descripción: El host responde a paquetes TCP con la opción de timestamps activada (RFC 1323), lo que permite inferir información sobre el uptime del sistema, frecuencia de reloj o posibles patrones de tráfico. Esto puede ayudar en ataques de fingerprinting pasivo o en combinación con otras técnicas (ej. estimar tiempo de arranque para ataques de secuencia de números).
- Impacto: Bajo – no permite explotación directa, solo recopilación pasiva de datos que ya son visibles en tráfico de red.
- CVE asociada: No aplica CVE específica (es una característica del protocolo TCP, no un bug explotable).
- Recomendación típica: Deshabilitar TCP timestamps en el firewall o configuración del kernel (`sysctl net.ipv4.tcp_timestamps=0`), si no es necesario para optimizaciones de conexión.
- No se encontraron otras issues accionables (sin CVEs explotables, sin misconfigurations graves, sin exposición de servicios vulnerables).

Captura de pantalla:

1 - 1 of 1									
Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓	EPSS Score ↑↓	Percentile ↑↓	Created ↑↓	
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	98.64.11.144	tomtom.com	general/tcp	N/A	N/A	Mon, Mar 2, 2026 9:56 AM Coordinated Universal Time	

(Extracto del reporte de OpenVAS mostrando el hallazgo de "TCP Timestamps Information Disclosure")

Observaciones / hallazgos relevantes:

- El hallazgo es típico en servidores Linux/Unix modernos que mantienen TCP timestamps activados por defecto para mejorar el rendimiento de conexiones (PAWS – Protection Against Wrapped Sequences).
- No representa un riesgo significativo por sí solo en entornos con WAF y hardening adecuado (como el observado en tomtom.com).

- OpenVAS confirma la ausencia de vulnerabilidades directas o graves, alineándose con resultados previos de nuclei (dominio principal limpio) y wafw00f (protección fuerte en endpoints clave).
- Este tipo de issue leve es común en escaneos de red y suele mitigarse con configuraciones de firewall o políticas de red.

4.3 Detección de subdominios vulnerables con subzy

Herramienta utilizada: subzy (herramienta rápida y eficiente para comprobar si los subdominios son vulnerables, analizando registros CNAME y comparándolos con fingerprints conocidos de servicios cloud).

Descripción del proceso:

1. Se ejecutó subzy contra la lista final de subdominios vivos.
2. Comando: *subzy run -targets objetivos_ok.txt*
3. Subzy comprobó cada subdominio buscando registros CNAME y comparándolos con su base de fingerprints de proveedores cloud populares.
4. Inicialmente reportó **bastantes vulnerabilidades** (subdominios con posible takeover).
5. Se realizó una **verificación manual conjunta** de cada hallazgo reportado:
 - Consulta de registros DNS (dig CNAME subdominio) para ver a qué apunta.
 - Resolución de la IP del CNAME (dig).
 - Comprobación si la IP pertenece a rangos de Azure (Microsoft Azure cloud).
 - Acceso manual o chequeo de respuesta HTTP para confirmar si el recurso existe y está activo (no dangling).

Resultados obtenidos:

- Subzy reportó inicialmente varias vulnerabilidades de subdomain takeover (subdominios con CNAMEs que coincidían con fingerprints de servicios cloud, principalmente Azure-related).
- Tras la verificación manual conjunta de cada caso reportado:

- Todos los CNAMEs apuntaban a nombres internos o recursos válidos de Azure (ej. blob.core.windows.net, azurewebsites.net, o similares con nombres custom de TomTom).
- Las IPs resueltas pertenecían a rangos públicos de Microsoft Azure (confirmado por whois de IP o geolocalización cloud).
- Los endpoints respondían correctamente (200 OK, redirecciones o contenido esperado), indicando que los recursos están activos y correctamente configurados por TomTom.
- **Conclusión de la verificación:** Todos los hallazgos de subzy fueron **falsos positivos**. No existe ningún subdominio dangling/vulnerable a takeover real.

Captura de pantalla:

```
(kali@kali)-[~/tomtom.com]
$ subzy run --targets objetivos_ok.txt
[ * ] Fingerprints not found; saving them to "/home/kali/subzy/fingerprints.json"
[ * ] Loaded 73 targets
[ * ] Loaded 76 fingerprints
[ No ] HTTPS by default (--https)
[ 10 ] Concurrent requests (--concurrency)
[ No ] Check target only if SSL is valid (--verify_ssl)
[ 10 ] HTTP request timeout (in seconds) (--timeout)
[ No ] Show only potentially vulnerable subdomains (--hide_fails)
[ NOT VULNERABLE ] - dev.tomtom.com

[ VULNERABLE ] - home.tomtom.com [ UptimeRobot ]
[ DISCUSSION ] - [Issue #45](https://github.com/EdOverflow/can-i-take-over-xyz/issues/45)
[ DOCUMENTATION ] - [UptimeRobot-Sub-takeover](https://exploit.linuxsec.org/uptime-robot-com-custom-domain-subdomain-takeover/)

[ NOT VULNERABLE ] - community.tomtom.com
[ NOT VULNERABLE ] - engage.tomtom.com
[ NOT VULNERABLE ] - groups.tomtom.com
[ NOT VULNERABLE ] - create.tomtom.com
[ NOT VULNERABLE ] - events.tomtom.com
[ NOT VULNERABLE ] - help.tomtom.com

[ VULNERABLE ] - banner.tomtom.com [ Gemfury ]
[ DISCUSSION ] - [Issue #154](https://github.com/EdOverflow/can-i-take-over-xyz/issues/154)
[ DOCUMENTATION ] - [Article](https://khaledibnalwalid.wordpress.com/2020/06/25/gemfury-subdomain-takeover/)

[ NOT VULNERABLE ] - docs.tomtom.com
[ NOT VULNERABLE ] - intouch.tomtom.com

[ VULNERABLE ] - images.tomtom.com [ HubSpot ]
[ DISCUSSION ] - [Issue #59](https://github.com/EdOverflow/can-i-take-over-xyz/issues/59)
[ DOCUMENTATION ] -

[ VULNERABLE ] - click.tomtom.com [ Cargo Collective ]
[ DISCUSSION ] - [Issue #152](https://github.com/EdOverflow/can-i-take-over-xyz/issues/152)
[ DOCUMENTATION ] - [Cargo Support Page](https://support.2.cargocollective.com/Using-a-Third-Party-Domain)

[ NOT VULNERABLE ] - beat.tomtom.com
[ NOT VULNERABLE ] - demo.tomtom.com
[ NOT VULNERABLE ] - autodiscover.tomtom.com
```

(Resultado de subzy run sobre la lista de subdominios.)

Observaciones / hallazgos relevantes:

- Subzy es muy sensible y útil para detección rápida, pero genera falsos positivos cuando los servicios cloud (como Azure) usan CNAMEs custom o configuraciones internas válidas que coinciden con fingerprints genéricos.
- La verificación manual (DNS + resolución IP + chequeo de respuesta) fue clave para descartar todos los casos: todos apuntaban a infraestructura activa de Azure gestionada por TomTom.
- No se identificó ningún subdominio vulnerable a takeover real (ningún CNAME dangling a servicio eliminado o no reclamado).
- Este paso refuerza que la gestión de DNS y recursos cloud de TomTom es correcta y no presenta exposiciones conocidas de este tipo.

4.4 Análisis de configuración SSL/TLS con Qualys SSL Labs Server Test

Herramienta utilizada: Qualys SSL Labs Server Test (<https://www.ssllabs.com/ssltest/> – herramienta online gratuita y ampliamente reconocida para evaluar la calidad de la implementación SSL/TLS de un servidor, incluyendo protocolos, cifrados, certificados, handshake, vulnerabilidades conocidas y compatibilidad con clientes).

Descripción del proceso:

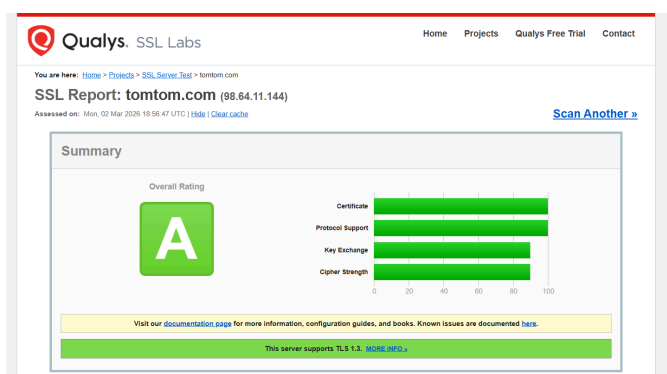
1. Se ingresó el dominio principal **tomtom.com**.
2. La herramienta realizó un escaneo completo del handshake TLS, analizando:
 - Certificado (cadena, validez, emisor, SANs, OCSP, CT, etc.).
 - Protocolos soportados (TLS 1.3, 1.2, etc.).
 - Suites de cifrado y key exchange.
 - Compatibilidad con clientes reales (browsers, bots, dispositivos antiguos).
 - Vulnerabilidades conocidas (Heartbleed, POODLE, ROBOT, etc.).
 - Configuraciones adicionales (HSTS, HPKP, ALPN, session resumption, etc.).
3. Se obtuvo un reporte detallado con calificación global y desglose por categoría.

Resultados obtenidos:

- **Calificación global: A** (excelente, sin fallos críticos).
- **Certificado:**
 - Emisor: HydrantID Server CA O1 (cadena completa hasta IdenTrust Commercial Root CA 1, trusted en todos los stores principales: Mozilla, Apple, Android, Java, Windows).
 - Tipo: RSA 2048 bits (SHA256withRSA), no weak key.
 - Validez: Desde 10 Oct 2025 hasta 04 Nov 2026 (expira en ~8 meses desde fecha actual).
 - Subject: url-redirector-prod.tomtomgroup.com
 - SANs (Alternative Names): Incluye múltiples dominios y subdominios de TomTom (tomtom.com, tomtom.dev, tomtomgroup.com, engage.tomtom.com, groups.tomtom.com, office365.tomtom.com, security.tomtomgroup.com, confluence.tomtomgroup.com, etc.).
 - Certificate Transparency: Sí.
 - OCSP/CRL: Presentes y válidos (revocation status: Good).
 - No EV (Extended Validation), no OCSP Must-Staple, no DNS CAA.
- **Protocolos soportados:**
 - TLS 1.3: Sí (recomendado).
 - TLS 1.2: Sí.
 - TLS 1.1 / 1.0 / SSL 3 / SSL 2: No (correcto, versiones obsoletas deshabilitadas).
- **Cipher Suites y Key Exchange:**
 - TLS 1.3: TLS_AES_256_GCM_SHA384 y TLS_AES_128_GCM_SHA256 (ECDHE con x25519, Forward Secrecy).
 - TLS 1.2: ECDHE_RSA con AES-GCM (256/128) y SHA384/SHA256 (ECDHE x25519/secp256r1, FS).
 - No RC4, no 3DES, no DHE (solo ECDHE), no common DH primes reutilizados.
- **Compatibilidad con clientes:**
 - Excelente en clientes modernos (Android 5+, Chrome 69+, Firefox 62+, Edge 15+, Safari 10+, Java 11+, etc.).

- Algunos clientes antiguos (IE 11 en Win 7/8.1/Phone, Safari 6-8, IE 11 en Win Phone) fallan handshake o usan protocolos no soportados (esperado y seguro).
- **Vulnerabilidades y configuraciones:**
 - Ninguna vulnerabilidad crítica o explotable detectada (Heartbleed, POODLE, ROBOT, CCS Injection, Padding Oracle, Ticketbleed, etc. = No).
 - Secure Renegotiation: Supported.
 - HSTS: No implementado (ni Preloading).
 - HPKP / HPKP Report-Only: No.
 - Session resumption (tickets): Sí; caching: No.
 - ALPN/NPN: Sí (http/1.1).
 - 0-RTT: No.
 - Otros: BEAST mitigado server-side, no compression, no insecure renegotiation, no downgrade attack (TLS_FALLBACK_SCSV).
- **Pequeños fallos / buenas prácticas:**
 - Política HSTS ausente (recomendable activar).
 - No OCSP Must-Staple.
 - No HPKP (obsoleto, pero opcional).
 - Algunos clientes muy antiguos no compatibles (pero irrelevante en 2026).
 - Estos son solo recomendaciones de hardening, no defectos explotables ni reportables en bounty programs.

Captura de pantalla:



(Resumen del reporte SSL Labs con calificación global A)

Observaciones / hallazgos relevantes:

- El servidor HTTPS de TomTom presenta una configuración moderna y segura: TLS 1.3 prioritario, Forward Secrecy robusto, cifrados fuertes, cadena de certificados trusted y sin vulnerabilidades conocidas.
- Los "pequeños fallos" señalados (falta de HSTS, OCSP Must-Staple, compatibilidad con clientes muy obsoletos) son mejoras recomendadas, no issues explotables ni elegibles para bug bounty.
- El certificado cubre múltiples dominios/subdominios de TomTom (incluyendo redirecciones y servicios internos/externos), lo que indica buena gestión centralizada.
- Este análisis confirma que la capa TLS está bien hardening, alineándose con resultados previos de nuclei y OpenVAS (solo issues leves/no explotables).

4.5 Análisis de configuración de correo electrónico (SPF, DKIM y DMARC) con dmarcian Domain Checker

Herramienta utilizada: dmarcian Domain Checker (herramienta online gratuita en <https://dmarcian.com/domain-checker/> para validar y analizar registros DNS relacionados con autenticación de correo: SPF, DKIM y DMARC. Proporciona diagnóstico de validez, políticas y recomendaciones de mejora).

Descripción del proceso:

1. Se accedió a <https://dmarcian.com/domain-checker/> e ingresó el dominio principal **tomtom.com**.
2. La herramienta realizó consultas DNS automáticas para:
 - Registro SPF (TXT con v=spf1...).
 - Registros DKIM (selectores TXT en _domainkey o selector._domainkey).
 - Registro DMARC (TXT en _dmarc.tomtom.com).
3. Se obtuvo un reporte detallado con estado de cada protocolo, validez de sintaxis, política aplicada y recomendaciones.

4. Se revisó específicamente el registro DMARC para confirmar su existencia, política y modo de reporte.

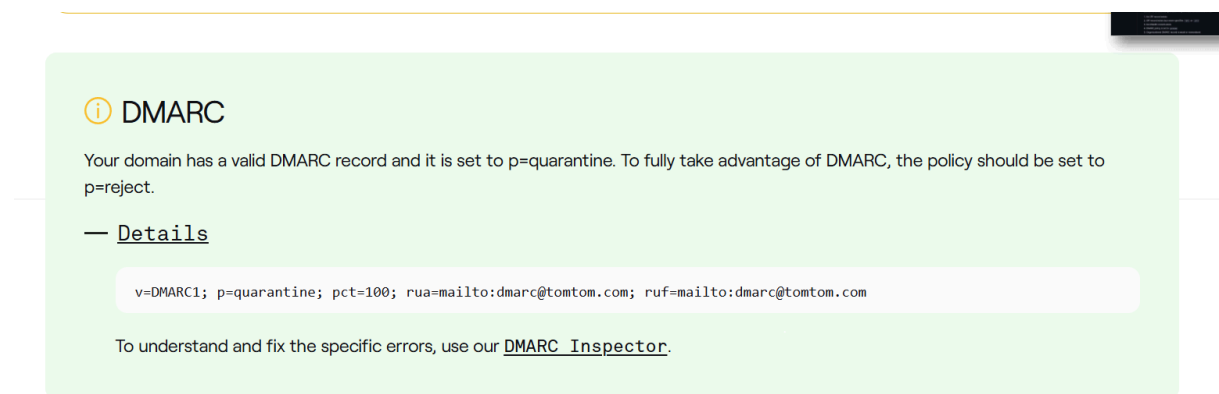
Resultados obtenidos:

- **SPF y DKIM:** Ambos están correctamente configurados y válidos (la herramienta confirma que no hay errores de sintaxis ni problemas graves detectados en los registros publicados).
- **DMARC:** El dominio tiene un registro DMARC válido y activo. Detalles del registro DMARC extraídos del reporte:
text
v=DMARC1; p=quarantine; pct=100; rua=mailto:dmarc@tomtom.com;
ruf=mailto:dmarc@tomtom.com
 - **Política (p=):** quarantine → Los correos que fallen SPF/DKIM se envían a la carpeta de spam/cuarentena (no se rechazan directamente).
 - **pct=100:** Aplica la política al 100% de los correos.
 - **rua / ruf:** Reportes agregados y forenses se envían a dmarc@tomtom.com (correo interno para monitoreo).
- Recomendación de dmarcian: Para maximizar la protección contra spoofing/phishing, se sugiere elevar la política a **p=reject** (rechazo total de correos no autenticados) en lugar de quarantine.
- No se detectaron errores críticos ni fallos de implementación en SPF/DKIM/DMARC.

Capturas de pantalla:



(Resultado del chequeo en <https://dmarcian.com/domain-checker/> para tomtom.com, mostrando validez de SPF/DKIM)



(Extracto específico del reporte DMARC)

Observaciones / hallazgos relevantes:

- TomTom mantiene una configuración sólida de autenticación de correo: SPF y DKIM correctos evitan spoofing básico, y DMARC en modo quarantine ofrece protección parcial con monitoreo activo (reportes enviados).
- La política quarantine es conservadora (permite entrega en spam en lugar de rechazo), lo que reduce falsos positivos pero deja margen para mejorar (pasar a reject sería más estricto).
- No se identificaron vulnerabilidades graves en esta área (ej. SPF demasiado permisivo, DKIM ausente o DMARC sin política).

- Este análisis complementa el fingerprinting general, confirmando que el correo corporativo está protegido contra abusos comunes.

5. OSINT y análisis de RRSS.

5.1 Uso de Maltego para reconocimiento OSINT inicial

Herramienta utilizada: Maltego (plataforma de análisis OSINT y link analysis que permite mapear relaciones entre entidades: dominios, subdominios, personas, correos, redes sociales, etc., mediante transforms y fuentes públicas).

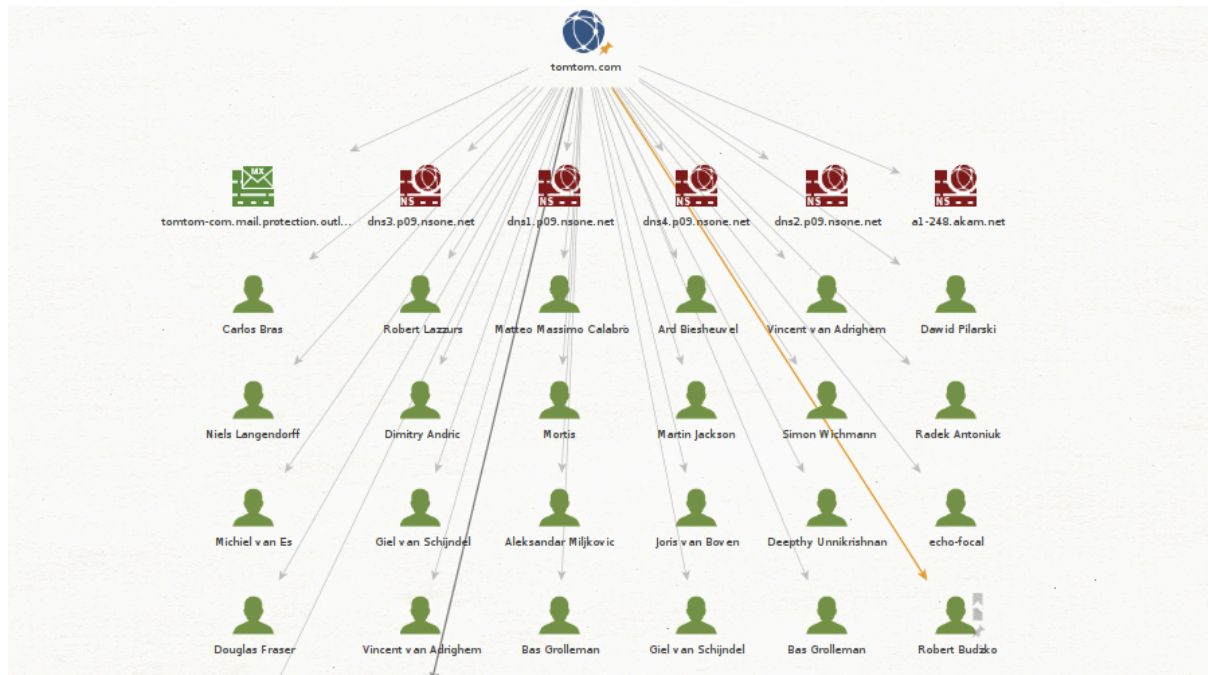
Descripción del proceso:

1. Se creó un nuevo graph en Maltego con la entidad principal **tomtom.com** (Domain).
2. Se aplicaron transforms de DNS y reconnaissance para descubrir subdominios, servidores asociados y otros dominios relacionados.
3. Se utilizaron transforms de People y Company para buscar empleados, perfiles públicos y correos asociados a la organización TomTom.

Resultados obtenidos:

- Se identificaron **múltiples dominios y subdominios** adicionales vinculados a TomTom a través de DNS y transforms de infraestructura (ej. variaciones corporativas, regionales o de productos).
- Se encontraron **varios trabajadores/empleados** con presencia pública (perfiles LinkedIn, GitHub, etc.), confirmando la estructura organizativa visible en fuentes abiertas.

Captura de pantalla:



(Grafico de Maltego mostrando entidades relacionadas con tomtom.com)

Observaciones / hallazgos relevantes:

- Maltego permitió una visualización rápida de la huella digital pública de TomTom, incluyendo infraestructura DNS y personas clave.

5.2 Búsqueda manual de empleados en LinkedIn

Descripción del proceso:

1. Se realizó una búsqueda manual en LinkedIn con los nombres de los empleados facilitados por Maltego.
2. Se identificó un perfil relevante de larga trayectoria en la empresa.

Resultados obtenidos:

- Perfil encontrado: **Giel van Schijndel**
 - Cargo: Senior Engineer en TomTom.

- Antigüedad: **11 años** en la compañía (confirmado en su perfil LinkedIn).
- Ubicación y otros detalles visibles públicamente según el perfil.

Captura de pantalla:

Giel van Schijndel ✓

Beschikbaar | Senior Software Engineer | C++ Specialist

Área metropolitana de Brabante · [Información de contacto](#)

306 contactos

[Enviar mensaje](#) [+ Seguir](#) [Más](#)

Acerca de

I seek to understand problems in depth before committing to solutions. To develop solutions in such a way to leave open the possibility to change directions with minimal effort for as long as possible. To stay aware that knowledge is always limited, to track assumptions derived from that knowledge. To keep testing those assumptions, preferably in an automated way.... [... ver más](#)

Actividad

330 seguidores

Giel aún no ha publicado nada

Las publicaciones recientes que Giel comparta aparecerán aquí.

[Mostrar toda la actividad →](#)

Experiencia

 **Expert Software Engineer**

TomTom · Jornada completa

jul. 2014 - nov. 2025 · 11 años 5 meses

Eindhoven · Híbrido

(Extracto del perfil LinkedIn de Giel van Schijndel, destacando su rol como Senior Engineer y 11 años de antigüedad en TomTom.)

Observaciones / hallazgos relevantes:

- Empleados con larga antigüedad como este pueden ser puntos de interés para OSINT adicional (publicaciones, repositorios, correos visibles, etc.), aunque en este caso el perfil es estándar y profesional.

5.3 Extracción de correos electrónicos asociados con Maltego

Descripción del proceso:

1. En el graph de Maltego, se seleccionó la entidad Persona (Giel van Schijndel) y se aplicaron transforms de Email Addresses o People Search para buscar correos asociados.
2. Maltego consultó fuentes públicas y bases de datos OSINT para correlacionar posibles direcciones de correo.

Resultados obtenidos:

- Se obtuvieron varias direcciones de correo potenciales vinculadas al perfil (incluyendo correos personales y posiblemente corporativos).
- No se obtuvo información adicional relevante o verificable directamente desde estos correos en esta fase.

Captura de pantalla:



(Grafico en Maltego mostrando correos electrónicos asociados a la entidad Giel van Schijndel, extraídos de fuentes públicas.)

5.4 Comprobación de brechas de datos en Have I Been Pwned (HIBP)

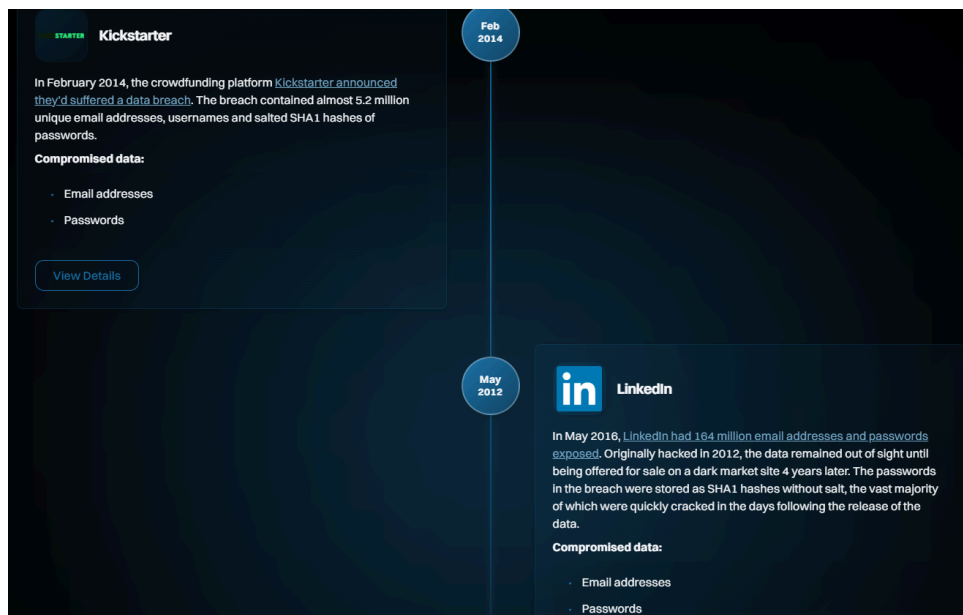
Descripción del proceso:

1. Se consultó <https://haveibeenpwned.com/> para varios correos encontrados (incluyendo el ejemplo me@mortis.eu y el correo corporativo de TomTom asociado).
2. Se revisaron las brechas listadas, fechas y tipos de datos expuestos (emails, contraseñas, números de teléfono, redes sociales, etc.).

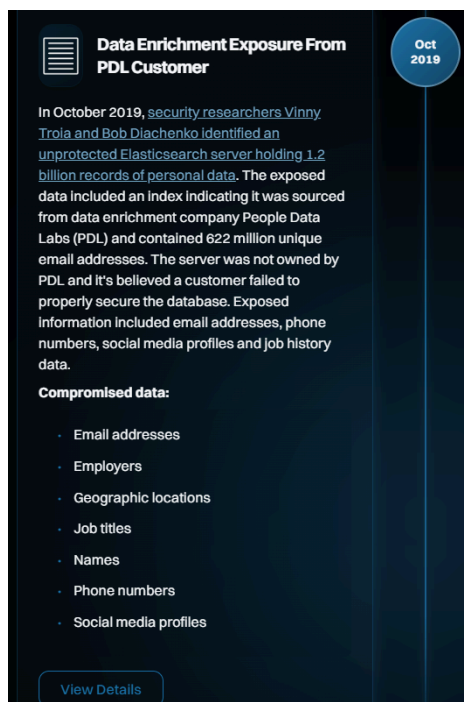
Resultados obtenidos:

- Para el correo personal **me@mortis.eu**:
 - Aparece en **6 brechas de datos** (databrezes).
 - Entre ellas: LinkedIn (2012) y Kickstarter (2014), donde se expusieron usuarios y contraseñas (hashes).
 - Otras brechas pueden incluir emails, IPs o datos adicionales.
- Para el correo corporativo (ej. asociado a TomTom):
 - Aparece en **solo 1 brecha**.
 - En esa brecha se expusieron correos electrónicos, números de teléfono, redes sociales y otros datos personales.

Capturas de pantalla:



(Resultado en Have I Been Pwned para me@mortis.eu)



(Consulta en Have I Been Pwned para un correo corporativo de TomTom, reportando una única brecha con exposición de correos, números de teléfono y perfiles de redes sociales.)

Observaciones / hallazgos relevantes:

- Las brechas antiguas (2012–2014) son comunes en plataformas como LinkedIn y Kickstarter; las contraseñas expuestas probablemente ya no son válidas.
- La brecha del correo corporativo expone datos de contacto (teléfonos, redes sociales), lo que amplía la superficie OSINT para ingeniería social o phishing targeted, aunque no representa credenciales activas.
- Ninguna brecha reciente o crítica fue detectada en este análisis.

5.5 Análisis de metadatos con ExifRay

Herramienta utilizada: ExifRay (herramienta para extracción exhaustiva de metadatos de archivos de imagen y PDF, incluyendo campos EXIF, XMP, IPTC, PDF properties, software utilizado, autores/usuarios internos, fechas de creación/modificación y otros tags ocultos).

Descripción del proceso:

1. Se recopilaron imágenes y/o PDFs públicos o expuestos en el dominio tomtom.com (ej. desde páginas de productos, informes, mapas, imágenes corporativas o documentos descargables).
2. Se procesaron los archivos con ExifRay para extraer todos los metadatos disponibles (software de creación/edición, usuarios del sistema, versiones de herramientas Adobe, etc.).
3. Se analizó la salida para identificar patrones: herramientas de diseño (Adobe suite), usuarios internos visibles, versiones antiguas de software y posibles leaks de información operativa.

Resultados obtenidos:

Se extrajeron metadatos de varios archivos analizados. A continuación, la lista consolidada de los principales tags relevantes detectados (sin duplicados ni campos irrelevantes):

- **Software / Herramientas de creación/edición:**
 - Adobe PDF Library 16.07, 17.0, 15.0, 9.00, 6.0

- Adobe Illustrator 26.3 (Macintosh), CS4
- Adobe InDesign 18.1 (Macintosh), 18.0 (Macintosh), CS (3.0)
- Adobe Photoshop Version 9.0x196, 27.2 (Macintosh)
- Acrobat Distiller 7.0.5 (Windows), 8.1.0 (Windows)
- Microsoft Word 2010, Microsoft® Word 2010
- FrameMaker 8.0
- Akamai Image Manager
- Next.js (framework web, posiblemente en imágenes generadas dinámicamente)
- Acrobat Web Capture 6.0
- **Usuarios / Autores internos:**
 - Claire Walker
 - dao
 - tomtom (posible username o tag corporativo genérico)

Captura de pantalla:

```
(kali@kali)-[~/tomtom.com]
$ cat exifray.txt
[Software] Adobe PDF library 16.07
[Software] Adobe Illustrator 26.3 (Macintosh)
[Software] Adobe PDF Library 17.0
[Software] Adobe InDesign 18.1 (Macintosh)
[Software] Adobe PDF Library 6.0
[Software] Adobe InDesign CS (3.0)
[Users] Claire Walker
[Software] Microsoft Word 2010
[Software] Adobe PDF Library 15.0
[Software] Akamai Image Manager
[Software] Next.js
[Software] Adobe InDesign 18.0 (Macintosh)
[Users] dao
[Software] Acrobat Distiller 7.0.5 (Windows)
[Software] Adobe Photoshop Version 9.0x196
[Software] Acrobat Web Capture 6.0
[Software] Acrobat Distiller 8.1.0 (Windows)
[Software] FrameMaker 8.0
[Software] tomtom
[Software] Adobe PDF library 9.00
[Software] Adobe Illustrator CS4
[Software] Microsoft® Word 2010
[Software] Adobe Photoshop 27.2 (Macintosh)
```

(Output de ExifRay mostrando los metadatos extraído.)

Observaciones / hallazgos relevantes:

- Predominio de la suite Adobe (Illustrator, InDesign, Photoshop, Acrobat Distiller, PDF Library) en versiones variadas (desde antiguas como CS3/CS4 o Acrobat 7/8 hasta recientes como InDesign 18.x y Photoshop 27.2), indicando un flujo de trabajo de diseño gráfico y producción de documentos/PDFs corporativo.
- Usuarios internos visibles (Claire Walker, dao) sugieren posibles autores de assets públicos; podrían correlacionarse con perfiles LinkedIn o redes sociales en fases posteriores de OSINT.
- Presencia de **Next.js** (framework React para web) y **Akamai Image Manager** (optimización de imágenes vía CDN Akamai) indica que algunas imágenes provienen de sitios web dinámicos o procesadas en CDN.
- Versiones antiguas de software (ej. Acrobat Distiller 7/8, Illustrator CS4, Photoshop 9.0) podrían indicar archivos legacy reutilizados o no actualizados, aunque no representan vulnerabilidades directas.
- No se detectaron metadatos sensibles como coordenadas GPS, fechas de captura precisas o contraseñas, pero la exposición de nombres de usuarios internos y herramientas específicas amplía el perfil OSINT de la organización (posible vector para ingeniería social o correlación con empleados).